

Chapter 05

2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드

네트워크 장비

1. 계정 관리	391
2. 접근 관리	406
3. 패치 관리	422
4. 로그 관리	424
5. 기능 관리	431

01 네트워크 장비 취약점 분석 · 평가 항목

1. 계정 관리

점검항목	항목 중요도	항목코드
비밀번호 설정	상	N-01
비밀번호 복잡성 설정	상	N-02
암호화된 비밀번호 가용	상	N-03
계정 잠금 임계값 설정	상	N-04
사용자, 명령어별 권한 수준 설정	중	N-05

2. 접근 관리

점검항목	항목 중요도	항목코드
VTY 접근(ACL) 설정	상	N-06
세션 종료 시간 설정	상	N-07
VTY 접속 시 안전한 프로토콜 사용	중	N-08
불필요한 보조 입출력 포트 사용 금지	중	N-09
로그온 시 경고 메시지 설정	중	N-10
원격 로그 서버 사용	중	N-11

3. 패치 관리

점검항목	항목 중요도	항목코드
주기적 보안 패치 및 벤더 권고사항 적용	상	N-12

05. 네트워크 장비

4. 로그 관리

점검항목	항목 중요도	항목코드
로깅 버퍼 크기 설정	중	N-13
정책에 따른 로깅 설정	중	N-14
NTP 및 시각 동기화 설정	중	N-15
Timestamp 로그 설정	하	N-16

5. 기능 관리

점검항목	항목 중요도	항목코드
SNMP 서비스 확인	상	N-17
SNMP Community String 복잡성 설정	상	N-18
SNMP ACL 설정	상	N-19
SNMP Community 권한 설정	상	N-20
TFTP 서비스 차단	상	N-21
Spoofing 방지 필터링 적용	상	N-22
DDoS 공격 방어 설정 또는 DDoS 장비 사용	상	N-23
사용하지 않는 인터페이스 비활성화	상	N-24
TCP Keepalive 서비스 설정	중	N-25
Finger 서비스 차단	중	N-26
웹 서비스 차단	중	N-27
TCP/UDP small 서비스 차단	중	N-28
Bootp 서비스 차단	중	N-29
CDP 서비스 차단	중	N-30
Directed-broadcast 차단	중	N-31
Source 라우팅 차단	중	N-32
Proxy ARP 차단	중	N-33

점검항목	항목 중요도	항목코드
ICMP unreachable, Redirect 차단	중	N-34
identd 서비스 차단	중	N-35
Domain Lookup 차단	중	N-36
pad 차단	중	N-37
mask-reply 차단	중	N-38

05. 네트워크 장비

N-01 (상)	네트워크 장비 > 1. 계정 관리
	비밀번호 설정
개요	
점검 내용	관리 터미널(콘솔, SSH, https 등)을 통해 네트워크 장비 접근 시 기본 비밀번호(기본 관리자 계정도 함께 변경하도록 권고)를 사용하는지 점검
점검 목적	기본 비밀번호를 변경하지 않고 사용함으로써 발생할 수 있는 비인가자의 네트워크 장비 접근에 대한 통제가 이루어지는지 확인하기 위함
보안 위협	- 장비 출고 시 설정된 기본 비밀번호를 변경하지 않고 그대로 사용할 경우 비인가자가 인터넷을 통해 벤더사 별 네트워크 장비 기본 비밀번호를 쉽게 획득할 수 있음 - 획득한 비밀번호를 사용하여 기본 비밀번호를 변경하지 않고 관리 운용 중인 네트워크 장비에 접근하여 장비의 내부 설정(ACL)을 변경함으로써 해당 네트워크 장비를 통해 전송되는 데이터들이 비인가자에게 유출되거나 네트워크 장비를 통해 통신하는 정보시스템(서버, 보안 장비, 네트워크 장비) 간의 통신에 영향(데이터 전송 불가)을 미칠 수 있음
참고	※ 기본(Default) 비밀번호: 장비 제조업체에서 출고 시 설정되어 나오는 기본 관리자 계정의 비밀번호 정보 ※ 기본(Default) 관리자 계정: 장비 제조업체에서 출고 시 설정되어 나오는 네트워크 장비의 관리용 계정(예: admin, manager 등)
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : 기본 비밀번호를 변경한 경우
	취약 : 기본 비밀번호를 변경하지 않거나 비밀번호를 설정하지 않은 경우
조치 방법	기본 비밀번호를 관리기관의 비밀번호 작성규칙을 준용하여 변경
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) enable 비밀번호 설정 확인

Router> enable

Router# show running-config

Step 2) VTY, 콘솔, 보조(AUX) 포트의 로그인 인증 방식 및 비밀번호 설정 확인

login: 라인 비밀번호 인증

login local: 로컬 사용자 인증

login authentication: AAA 인증

no login: 인증 없이 사용자 모드(User EXEC mode) 접근

Step 3) enable 비밀번호 설정

Router# config terminal (단축 명령 conf t)

Router(config)# enable secret <비밀번호> 또는 Router(config)# enable password <비밀번호>

Router(config)# end

Step 4) 가상 터미널(VTY) 비밀번호 설정

Router# config terminal

Router(config)# line vty ?

<0X4> First Line number

Router(config)# line vty 0 4

Router(config-line)# login

Router(config-line)# password <비밀번호>

Step 5) 콘솔 비밀번호 설정

Router# config terminal

Router(config)# line console ?

<0X0> First Line number

Router(config)# line console 0

Router(config-line)# login

Router(config-line)# password <비밀번호>

Step 6) 보조(AUX) 포트 비밀번호 설정

Router# config terminal

Router(config)# line aux ?

<0X0> First Line number

Router(config)# line aux 0

Router(config-line)# login

Router(config-line)# password <비밀번호>

※ AUX 포트는 일반적으로 무단 접근을 방지하기 위해 N-18 항목(불필요한 보조 입출력 포트 사용 금지)과 같이 비활성화 설정

● Radware Alteon

Step 1) admpw 설정 확인

```
Main# /cfg/dump
```

Step 2) 관리자 비밀번호 변경

```
Main# /cfg/sys/access/user/admpw (administrator 비밀번호 변경 시)
```

```
Main# apply
```

```
Main# save
```

● Passport

Step 1) 비밀번호 설정 확인

```
# show config
```

Step 2) switch 접속

Step 3) 다음 해당하는 계정에 따라 명령어 실행

```
# config cli password ro <계정명>
```

```
# config cli password 11 <계정명>
```

```
# config cli password 12 <계정명>
```

```
# config cli password 13 <계정명>
```

```
# config cli password rw <계정명>
```

```
# config cli password rwa <계정명>
```

```
# config cli password slboper <계정명>
```

```
# config cli password 14oper <계정명>
```

```
# config cli password oper <계정명>
```

```
# config cli password slbadmin <계정명>
```

```
# config cli password 14admin <계정명>
```

```
# config cli password ssladmin <계정명>
```

● Juniper Junos

Step 1) root authentication 설정 확인

```
user@host> configure
```

```
[edit]
```

```
user@host# show
```

Step 2) 루트 사용자 계정의 비밀번호를 변경

```
user@host> configure
```

```
[edit]
```

```
user@host# set system root-authentication plain-test-passwd
```

```
New password : <비밀번호>
```

```
retype new password : <비밀번호>
```

● Piolink PLOS

Step 1) 비밀번호 설정 확인

```
switch# show running-config
```

Step 2) 루트 사용자 계정의 비밀번호를 변경

```
# configure terminal
```

```
(config) # password
```

```
Changing password for root
```

```
Enter the new password (minimum of 5, maximum of 8 characters)
```

```
Enter new password: <비밀번호>
```

```
Re-enter new password: <비밀번호>
```


05. 네트워크 장비

N-02 (상)	네트워크 장비 > 1. 계정 관리
	비밀번호 복잡성 설정
개요	
점검 내용	네트워크 장비에 기관 정책에 맞는 계정 비밀번호 복잡성 정책이 적용되어 있는지 점검 비밀번호 복잡성 정책 설정 기능이 장비에 존재하지 않는 경우 기관 정책에 맞게 계정 비밀번호를 설정하여 사용하는지 점검
점검 목적	비인가자의 네트워크 장비 터미널(콘솔, SSH, https 등) 접근 시도 공격(무차별 대입 공격, 사전 대입 공격 등)에 대한 대비 여부를 확인하기 위함
보안 위험	비밀번호 복잡성 정책이 적용되어 있지 않을 경우 계정 생성 후 초기 비밀번호 설정 및 기존 비밀번호 변경 시 비밀번호 복잡성 제약 규칙을 적용받지 않아 취약한 비밀번호(예 qwerty, 12345, pass1234 등)를 설정할 수 있도록 허용되므로, 해당 취약점으로 인해 비인가자의 공격(무차별 대입 공격, 사전 대입 공격 등)에 계정 비밀번호가 유출되는 원인을 제공하여 유출된 비밀번호를 사용하여 비인가자가 네트워크 장비 터미널에 접근할 위험이 존재함
참고	※ 비밀번호 복잡성: 계정 비밀번호 설정 시 영문(대문자, 소문자), 숫자, 특수문자가 혼합된 비밀번호로 설정하는 것 ※ 무차별 대입 공격(Brute Force Attack): 컴퓨터로 암호를 해독하기 위해 가능한 모든 키를 하나하나 추론해 보는 시도를 말함. ※ 사전 대입 공격(Dictionary Attack): 사전에 있는 단어를 입력하여 비밀번호를 알아내거나 암호를 해독하는 데 사용되는 컴퓨터 공격 방법
점검 대상 및 판단 기준	
대상	공통
판단 기준	양호 : 기관 정책에 맞는 비밀번호 복잡성 정책을 설정하거나, 비밀번호 복잡성 설정 기능이 없는 장비는 기관 정책에 맞게 비밀번호를 사용하는 경우
	취약 : 기관 정책에 맞지 않는 비밀번호를 설정하여 사용하는 경우
조치 방법	관리기관의 비밀번호 작성규칙에 맞게 비밀번호 복잡성 정책 및 비밀번호 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● 공통

Step 1) 장비에 비밀번호 복잡성 정책을 설정하거나 비밀번호 복잡성 설정 기능이 없는 장비는 기관 정책에 따라 비밀번호를 설정하여 사용하는지 확인

Step 2) 기반시설 관리기관의 비밀번호 작성규칙과 관련 법규를 준수하여 비밀번호 복잡성 정책을 설정하고 안전한 비밀번호를 사용

※ 비밀번호 작성규칙 예시

비밀번호는 다음 사항을 반영하고 숫자·문자·특수문자 등을 혼합하여 안전하게 설정하고 정기적으로 변경·사용해야 함

1. 사용자 계정(아이디)과 동일하지 않은 것
2. 개인 신상 및 부서 명칭 등과 관계가 없는 것
3. 일반 사전에 등록된 단어의 사용을 피할 것
4. 동일한 단어 또는 숫자를 반복하여 사용하지 말 것
5. 사용된 비밀번호는 재사용하지 말 것
6. 동일한 비밀번호를 여러 사람이 공유하여 사용하지 말 것
7. 응용프로그램 등을 이용한 자동 비밀번호 입력기능을 사용하지 말 것

● Cisco IOS

Step 1) 비밀번호 복잡성 관련 설정 확인

```
Router# show running-config
```

Step 2) 비밀번호의 최소 길이 설정(기존 비밀번호는 영향을 받지 않음)

```
Router# config terminal
```

```
Router(config)#security passwords min-length ?
```

```
<0-16> Minimum length of all user/enable passwords
```

```
Router(config)# security passwords min-length <길이>
```

05. 네트워크 장비

N-03 (상)	네트워크 장비 > 1. 계정 관리
	암호화된 비밀번호 사용
개요	
점검 내용	계정 비밀번호 암호화 설정이 적용되어 있는지 점검
점검 목적	비인가자의 네트워크 장비 터미널 접근으로 인해 발생할 수 있는 장비 내 계정 비밀번호 유출에 대비가 되어있는지 확인하기 위함
보안 위협	계정 비밀번호 암호화 기능이 설정되어 있지 않을 경우, 비인가자가 네트워크 터미널에 접근하여 장비 내에 존재하는 모든 계정의 비밀번호를 획득할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : 비밀번호 암호화 설정을 적용한 경우
	취약 : 비밀번호 암호화 설정을 적용하지 않은 경우
조치 방법	비밀번호 암호화 설정 적용
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) enable secret 사용 확인

```
Router# show running-config
```

Step 2) 계정명 secret 사용 확인

```
Router# show running-config
```

Step 3) Password-Encryption 서비스 동작 확인

```
Router# show running-config
```

Step 4) enable secret 설정

enable secret 명령어를 사용하여 enable 비밀번호를 일방향 암호화 저장

enable secret 와 enable password 명령어로 각각 비밀번호를 사용하는 경우 enable secret 명령어의 우선순위가 높으며 보안상 비밀번호를 서로 다르게 입력해야 함

```
Router# config terminal
```

```
Router(config)# enable secret <비밀번호>
```

Step 5) username secret 설정

(config)# username secret 명령어를 사용하여 로컬 사용자 비밀번호를 일방향 암호화 저장
enable secret과 enable password 명령어로 비밀번호를 설정하여 같이 사용하는 경우 enable secret 명령
어로 설정한 비밀번호의 우선순위가 높으며 보안상 비밀번호 서로 다르게 입력해야 함

Router# config terminal

Router(config)# username <사용자 이름> secret <비밀번호>

Step 6) Password-Encryption 서비스 설정

구성파일(running-config/startup-config)에 평문 비밀번호를 양방향 암호화로 저장하여 노출을 방지, 해
독 가능한 알고리즘(비즈네르 암호)을 사용하기 때문에 구성정보에서 비밀번호를 제거하고 출력해야
하는 경우 show tech-support 명령어를 사용

Router# config terminal

Router(config)# service password-encryption

Router(config)# end

Router# show running-config

enable secret 5 \$1\$mERr\$9WCswBwUv6WeC6M8kNSs8

enable password 7 0822455D0A1648121C0A0E082F

● Juniper Junos

Step 1) root authentication 설정을 이용하여 [edit system] 레벨에서 비밀번호 암호화 설정

[edit]

user@host#show

Step 2) 기본적으로 비밀번호를 암호화 저장하며, encrypted-password 옵션은 이미 암호화된 비밀번호 해시를
직접 입력할 때 사용

[edit]

user@host# set system root-authentication encrypted-password <암호화된 비밀번호>

05. 네트워크 장비

N-04 (상)	네트워크 장비 > 1. 계정 관리
	계정 잠금 임계값 설정
개요	
점검 내용	사용자 계정에 대해 로그인 실패 임계값이 설정되어 있는지 점검
점검 목적	로그인 실패 임계값 초과 시 일정 시간 동안 계정 잠금을 실시하여 공격자의 자유로운 암호 추측 시도 및 리소스 낭비를 차단하고 무차별 대입 공격 등 비밀번호 탈취 공격을 무력화하기 위함
보안 위협	로그인 실패 시 일정 시간 동안 계정 잠금을 하지 않은 경우, 공격자의 자동화된 암호 추측 공격이 가능하고 비밀번호 탈취 공격(무차별 대입 공격, 사전 대입 공격 등)의 인증 요청에 대해 설정된 비밀번호와 일치할 때까지 지속적으로 응답하여 해당 계정의 비밀번호가 유출될 위험이 존재함
참고	※ 로그인 실패 임계값 : 시스템에 로그인 시 몇 번의 로그인 실패 이후 로그인을 차단할 것인지 결정하는 값
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : 로그인 실패 임계값이 5회 이하의 값으로 설정된 경우
	취약 : 로그인 실패 임계값이 설정되어 있지 않거나, 5회 초과로 설정된 경우
조치 방법	로그인 실패 임계값을 5회 이하로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) 현재 설정된 보안 정책 확인

Router# show running-config

1. login block-for 사용 확인

2. 로그인 실패 임계값 확인

Step 2) 로그인 실패 임계값 설정 확인

Router# show login

로그인 실패 임계값 설정 확인

Step 3) 로그인 실패 임계값 초과 후 계정 잠금 설정

login block-for 설정

Router# config terminal

Router(config)# login block-for <계정 잠금 시간> attempts <로그인 실패 횟수(default: 3)> within <로그

인 실패 허용 시간 범위(default: 15)>

● Juniper

Step 1) root authentication 설정을 이용하여 [edit system] 레벨에서 syslog 설정 확인

```
user@host> configure
```

```
[edit]
```

```
user@host# show version
```

Step 2) 로그인 실패 임계값 설정

```
user@host> configure
```

```
[edit system login retry-options]
```

```
user@host# set tries-before-disconnect <로그인 실패 횟수(default: 3)>
```

Step 3) 로그인 실패 임계값 초과 후 계정 잠금 시간 설정

```
user@host> configure
```

```
[edit system login retry-options]
```

```
user@host# set lockout-period <계정 잠금 시간>
```

05. 네트워크 장비

N-05 (중)	네트워크 장비 > 1. 계정 관리
	사용자·명령어별 권한 설정
개요	
점검 내용	네트워크 장비 사용자의 업무에 따라 계정별로 장비 관리 권한을 차등(관리자 권한은 최소한의 계정만 허용) 부여하고 있는지 점검
점검 목적	계정별 권한에 따라 장비의 사용 및 설정 가능한 기능을 제한하는지 확인하기 위함
보안 위협	계정별 권한이 차등 부여되어 있지 않은 경우, 일반 계정으로 장비의 모든 기능을 제어할 수 있어 일반 계정이 비인가자에 노출되었을 때 비인가자가 획득한 계정 정보를 통해 네트워크 장비에 접근하여 장비의 설정(ACL) 변경, 삭제 등의 행위를 하여 장비의 가용성(해당 장비를 통해 통신하는 정보시스템 간 데이터 전송 불가) 저하 문제가 발생할 위험이 존재함
참고	※ 관리자 계정 : 장비의 모든 기능(계정 생성 및 권한 부여, 장비 정책 설정, 모든 명령어 사용 가능 등)을 제한 없이 사용하거나 설정할 수 있는 계정 ※ 일반 계정 : 장비의 일부 기능(모니터링, 룰셋 적용, 일부 명령어만 사용 등) 만 사용하거나 설정할 수 있는 계정
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper, Pliolink 등
판단 기준	양호 : 업무에 맞게 계정의 권한이 차등 부여된 경우
	취약 : 업무에 맞게 계정의 권한이 차등 부여되지 않은 경우
조치 방법	업무에 맞게 계정별 권한 차등(관리자 권한 최소화) 부여 ※ 한 명의 관리자가 네트워크 장비를 관리할 경우는 해당하지 않음
조치 시 영향	해당 명령어 실행 시 권한 부족으로 실행되지 않을 수 있음

점검 및 조치 사례

● Cisco IOS

Step 1) 사용자·명령어별 레벨 설정 확인

Router# show privilege

Step 2) 사용자별 권한 수준 지정

Router# config terminal

Router(config)# 계정명 [ID] privilege [1-15] secret [PASS] 또는

Router(config)# 계정명 [ID] privilege [1-15] password [PASS]

Step 3) 명령어별 권한 수준 지정

Router(config)# privilege exec level [1-15] [서비스명]

아래의 중요한 명령어에는 반드시 레벨 15를 적용해야 함

connect, telnet, rlogin, show ip access-list, show logging

Router# config terminal

Router(config)# privilege exec level 15 connect

Router(config)# privilege exec level 15 telnet

Router(config)# privilege exec level 15 rlogin

Router(config)# privilege exec level 15 show ip access-list

Router(config)# privilege exec level 15 show logging

- ※ 시스코 IOS에서는 0에서 15까지 16개의 서로 다른 권한 수준을 규정하고 있으며, 레벨 1과 레벨 15는 기본적으로 정의되어 있음
- ※ 사용자 EXEC 모드는 레벨 1에서 실행되며 privileged EXEC 모드는 레벨 15에서 실행되고, IOS 각 명령어는 레벨 1이나 레벨 15 중 어느 하나의 레벨이 사전에 기본적으로 지정되어 있음
- ※ 레벨 1에서는 라우터의 설정 조회만 가능하고 레벨 15에서는 라우터의 전체 설정을 조회하고 변경할 수 있으므로 중요한 명령어의 권한 수준을 높여서 제한하는 것이 보안상 안전함

05. 네트워크 장비

● Radware Alteon

Step 1) 사용자의 접근 레벨이 7단계로 나누어져 있는지 확인

사용자 계정 / 기본 비밀번호	설명
User / User	User는 스위치 관리에 대한 직접적인 책임이 없지만 모든 스위치 상태 정보와 통계 자료를 볼 수 있음 그러나 스위치의 어떤 설정도 바꿀 수 없음
SLB Operator / slboper	SLB Operator는 Web 서버들과 다른 인터넷 서비스의 로드를 관리함 부가적으로 모든 스위치 정보와 통계를 볼 수 있으며, Server Load Balancing 운영 메뉴를 사용하는 서버의 사용 가능/사용 불가능을 설정할 수 있음
Layer4 Operator / l4oper	Layer4 Operator는 공유된 인터넷 서비스들에 따른 라인의 트래픽을 관리함 SLB Operator와 같은 접근 레벨을 가지고 있고, 공유된 인터넷 서비스들에 따른 라인의 트래픽을 관리하는 운영자를 위한 운영적인 명령어에 접근할 수 있도록 제공하는 위해서 접근 레벨은 향후에 사용하기 위해 예약되어 있음
Operator / oper	Operator는 모든 스위치의 기능을 관리함 부가적으로 SLB Operator 기능과 포트나 전반적인 스위치를 재설정할 수 있음
SLB Administrator / slbadmin	SLB Administrator는 웹서버들과 다른 인터넷 서비스들과 그것에 대한 로드를 설정 및 관리 할 수 있음 부가적으로 SLB Operator 기능들과 설정 필터들이나 대역폭 관리를 하는 것을 제외한 Server Load Balancing 메뉴에 매개변수를 설정할 수 있음
Layer4 Administrator / l4admin	Layer4 Administrator는 공유된 인터넷 서비스들에 따른 라인에 대한 트래픽을 설정 및 관리함 부가적으로 SLB Administrator 기능들, 설정 필터들이나 대역폭 관리 하는 것을 포함한 Server Load Balancing 메뉴에 모든 매개변수를 설정할 수 있음
Administrator / admin	superuser Administrator는 user와 administrator 비밀번호를 둘 다 변경할 수 있으며, Web 스위치의 모든 메뉴, 정보 그리고 설정 명령어들에 사용할 수 있음

Step 2) switch로 접속

Step 3) # cfg

Step 4) # sys

Step 5) 다음 중 해당하는 경우를 선택

/user/명령어

usrpw - user 암호 설정 및 변경

sopw - SLB operator 암호 설정 및 변경

l4opw - L4 operator 암호 설정 및 변경

opw - operator 암호 설정 및 변경

sapw - SLB administrator 암호 설정 및 변경

l4apw - L4 administrator 암호 설정 및 변경

admpw - administrator 암호 설정 및 변경

Step 6) 암호 및 설정 변경

Step 7) # apply

Step 8) # save

● Juniper Junos

Step 1) [edit system login]에서 superuser, read-only 클래스를 분리, 운영하는지 확인

Step 2) [edit system login] hierarchy level:

Step 3) [edit system]

```
login {10
  class class-name {
    allow-commands "regular-expression";
    deny-commands "regular-expression";
    idle-timeout minutes;
    permissions [ permissions ];
  }
}
```

※ 장비 구성 변경 시 사용하는 superuser 클래스와 monitoring 용으로 사용하는 read-only 클래스를 분리하여 사용할 것을 권장함. 장비 내 기본적으로 다음과 같은 클래스별 사용 권한 설정 및 세부 옵션 추가로 기능 제한을 할 수 있고, 특정 명령어 사용 제한을 계정마다 따로 설정할 수 있으므로 특정한 사용자 계정의 생성이 필요한 경우 사용 권한을 부여해야 함

05. 네트워크 장비

Class-name	Ability
Operator	clear, network, reset, trace, view
read-only	view
Superuser	all
unauthorized	None

● Piolink PLOS

Step 1) 슈퍼 유저(root)와 일반 유저로 권한을 부여하여 관리하는지 확인

Step 2) 디폴트 계정인 슈퍼 유저(root)와 관리목적에 따라 신규로 등록할 수 있는 일반 유저, 2단계로 나누어져 있음. 슈퍼 유저는 모든 권한이 부여되어 있으나 일반 유저의 경우 장비의 설정을 변경할 수 있는 권한이 없음. 따라서 사용자의 업무 및 권한에 따라 계정을 부여하여 관리하는 것이 보안상 중요함

N-06 (상)	네트워크 장비 > 2. 접근 관리
	VTY 접근(ACL) 설정
개요	
점검 내용	원격 터미널(VTY)을 통해 네트워크 장비 접근 시 지정된 IP에서만 접근할 수 있도록 설정되어 있는지 점검
점검 목적	지정된 IP만 네트워크 장비에 접근하여 비인가자의 터미널 접근을 원천적으로 차단하기 위함
보안 위협	지정된 IP만 네트워크 장비에 접근하도록 설정되어 있지 않을 경우, 비인가자가 터미널 접근 시도 공격(무차별 대입 공격, 사전 대입 공격 등)을 시도하여 관리자 계정 비밀번호 획득 후 네트워크 장비에 접근하여 장비 설정(기능, ACL정책) 변경 및 삭제 등의 행위를 통해 네트워크 장비를 경유하는 데이터의 유출 및 가용성 저하 등을 발생시킬 수 있는 위험이 존재함
참고	※ VTY(Virtual Type Terminal): 가상 유형 터미널의 약어. 가상 터미널 라인(virtual terminal line)이라는 용어가 더 흔하게 사용되며 네트워크 장비를 원격 프로토콜(ssh)에서 관리하기 위한 터미널 서비스 ※ 기반시설 시스템은 VTY를 통한 접근을 원칙적으로 금지하나, 부득이 VTY를 사용하여 접근해야 하는 경우 허용한 시스템만 접근할 수 있게 하여 사용해야 함
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : 가상 터미널(VTY) 접근을 제한하는 ACL을 설정한 경우
	취약 : 가상 터미널(VTY) 접근을 제한하는 ACL을 설정하지 않은 경우
조치 방법	가상 터미널(VTY)에 특정 IP주소만 접근할 수 있도록 설정
조치 시 영향	access-list를 생성하면 기본 Deny가 되므로 네트워크 담당자를 통해 설정함

점검 및 조치 사례

● Cisco IOS

Step 1) Access List 설정하고 VTY 라인에 적용 여부 확인

```
Router# show running-config
```

Step 2) VTY 접근 허용 IP 설정

```
Router# config terminal
```

```
Router(config)# access-list <ACL 번호> permit <IP주소>
```

```
Router(config)# access-list <ACL 번호> deny any log
```

```
Router(config)# line vty ?
```

```
<0X4> First Line number
```

05. 네트워크 장비

```
Router(config)# line vty 0 4
Router(config)# access-class <ACL 번호> in
```

● Radware Alteon

Step 1) 장비로 접속하여 Telnet 또는 SSH 사용자의 접속 IP 설정 확인(Access Policies)

Step 2) # cfg

```
# sys
# access
# mgmt
# add

Enter Management Network Address: <IP주소>
Enter Management Network Mask: <서브넷마스크>

# apply
# save
```

● Passport

Step 1) 장비로 접속하여 Telnet 또는 SSH 사용자의 접속 IP 설정 확인(Access Policies)

Step 2) # config sys access-policy

```
config/sys/access-policy# enable true
config/sys/access-policy# policy <pid> create
config/sys/access-policy# policy <pid>
config/sys/access-policy/policy/<pid># enable true
config/sys/access-policy/policy/<pid># accesslevel rwa
config/sys/access-policy/policy/<pid># host <ip-addr>
config/sys/access-policy/policy/<pid># service snmp enable
config/sys/access-policy/policy/<pid># service telnet enable
```

● Juniper Junos

Step 1) firewall filter 설정하고 루프백 인터페이스에 적용 여부 확인

```
[edit]
user@host# show
```

Step 2) 관리자 IP 지정

```
user@host> configure
[edit]
user@host# edit policy-options
[edit policy-options]
user@host# set prefix-list <prefix-name> <IP주소>
```

Step 3) SSH 서비스에 관리자 IP 외에 접근을 차단하도록 방화벽 필터를 설정

```
[edit]
user@host# edit firewall family inet filter <filter-name>
[edit firewall family inet filter <filter-name>]
user@host# edit term <term-name-1>
[edit firewall family inet filter <filter-name> term <term-name-1>]
user@host# set from source-address 0.0.0.0/0
user@host# set from source-prefix-list <prefix-name> except
user@host# set term from protocol tcp
user@host# set from destination-port ssh
user@host# set then log
user@host# set then discard
```

Step 4) SNMP, ICMP, BGP, OSPF 등 다른 서비스와 프로토콜에 필요한 접근허용 필터를 설정하지 않은 경우 방화벽 필터의 영향을 받지 않도록 기본 허용으로 구성을 종료

```
user@host# edit firewall family inet filter <filter-name>
[edit firewall family inet filter <filter-name>]
user@host# set term <term-name-2> then accept
```

※ 기본 허용으로 인한 보안 위협이 존재하므로 필요한 서비스와 프로토콜을 허용하고 기본 차단으로 더 강력한 보안 필터를 구성할 수 있음

Step 5) 루프백 인터페이스에 방화벽 필터를 적용

```
[edit]
user@host# set interfaces lo0 unit 0 family inet filter input
<filter-name>
```

● Piolink PLOS

Step 1) Security system access policy configuration 설정 확인

```
(config)# show running-config
```

Step 2) 시스템 접근 설정 모드에서 SSH 서비스에 ACL 설정

```
# configure terminal
```

```
(config)# security
```

```
(config-security)# system
```

```
(config-security-system)# access
```

```
(config-security-system-access)# rule <rule-id>
```

```
(config-security-system-access-rule[id])# protocol tcp
```

```
(config-security-system-access-rule[id])# source-ip <IP주소>
```

```
(config-security-system-access-rule[id])# dest-port 22
```

```
(config-security-system-access-rule[id])# interface any
```

```
(config-security-system-access-rule[id])# policy accept
```

```
(config-security-system-access-rule[id])# apply
```

Step 3) 시스템 접근 제어 기능의 기본 접근 정책을 차단으로 설정

```
(config-security-system-access) # default-policy deny
```

※ 기본 접근 정책을 차단으로 변경하기 전에 관리용 포트(mgmt)와 네트워크 장비에 SNMP, ICMP 등 다른 서비스와 프로토콜에 필요한 접근 허용 규칙을 모두 설정

N-07 (상)	네트워크 장비 > 2. 접근 관리
	Session Timeout 설정
개요	
점검 내용	기관 정책에 맞게 Session Timeout 설정이 적용되어 있는지 점검
점검 목적	Session Timeout 설정 유무를 점검하여 터미널 접속 후 일정 시간(Session Timeout 지정 시간)이 지난 뒤 터미널 세션이 자동으로 종료되어 관리자의 부재(터미널 작업 중 자리 비움, 작업 완료 후 터미널 접속을 종료하지 않음) 시 발생 가능한 비인가자의 터미널 접근 통제가 되는지 확인하기 위함
보안 위협	Session Timeout 정책이 적용되지 않았을 경우, 관리자 부재 시 비인가자가 네트워크 장비 터미널에 접속된 컴퓨터를 통해 네트워크 장비의 정책 변경 및 삭제 등의 행위를 할 수 있는 위험이 존재함
참고	※ Session Timeout : 터미널 접속 후 유휴 상태일 때 자동으로 터미널 접속을 종료하는 시간 설정
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper, Piolink 등
판단 기준	양호 : Session Timeout 시간을 10분 이하로 설정한 경우
	취약 : Session Timeout 시간을 설정하지 않거나 10분 초과로 설정한 경우
조치 방법	Session Timeout 설정 (10분 이하 권고)
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) 각 Line Access의 exec-timeout 설정 확인

```
Router# show running-config
```

Step 2) Console

```
Router# config terminal
```

```
Router(config)# line con 0
```

```
Router(config-line)# exec-timeout 5 0
```

Step 3) VTY

```
Router# config terminal
```

```
Router(config)# line vty 0 4
```

```
Router(config-line)# exec-timeout 5 0
```

Step 4) AUX

```
Router# config terminal
```



```
Router(config)# line aux 0
Router(config-line)# exec-timeout 5 0
```

● Radware Alteon

Step 1) idle timeout in minutes 설정 확인

Step 2) # cfg

```
# sys
# idle <idle timeout in minutes, affects both console and telnet>
# apply
# save
```

※ default : 5분 설정

● Juniper Junos

Step 1) idle-timeout 설정 확인

```
[edit]
user@host#show
```

Step 2) [edit login]

```
user@host#set class <클래스> idle-timeout <분>
```

● Piolink PLOS

Step 1) terminal timeout 설정 확인

Step 2) # configure terminal

```
(config)# terminal timeout <분>
```

※ 1분에서 60분 사이의 시간을 설정할 수 있음

N-08 (중)	네트워크 장비 > 2. 접근 관리
	VTY 접속 시 안전한 프로토콜 사용
개요	
점검 내용	네트워크 장비 정책에 암호화 프로토콜(ssh)을 이용한 터미널 접근만 허용하도록 설정되어 있는지 점검
점검 목적	암호화 프로토콜을 이용한 터미널 접근만 허용하여 네트워크 터미널 접근 시 전송되는 데이터의 스니핑 공격에 대한 대비가 되어 있는지 확인하기 위함
보안 위협	암호화 프로토콜이 아닌 평문 프로토콜(telnet)을 이용하여 네트워크 장비에 접근할 경우, 네트워크 스니핑 공격으로 관리자 계정 정보(계정, 비밀번호)가 비인가자에게 유출될 위험이 존재함
참고	※ 스니핑(임의 지정) 공격 : 스니퍼(Sniffer)는 "컴퓨터 네트워크상에 흘러 다니는 트래픽을 엿듣는 도청장치"라고 말할 수 있으며 "스니핑"이란 이러한 스니퍼를 이용하여 네트워크상의 데이터를 도청하는 행위를 말함
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper, Piolink 등
판단 기준	양호 : 장비 정책에 VTY 접근 시 암호화 프로토콜(ssh) 이용한 접근만 허용하고 있는 경우
	취약 : 장비 정책에 VTY 접근 시 평문 프로토콜(telnet) 이용한 접근을 허용하고 있는 경우
조치 방법	암호화 프로토콜만 VTY에 접근할 수 있도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) SSH 활성화 확인

```
Router# show ip ssh
```

```
SSH Enabled - version 1.5
```

```
Authentication timeout: 120 secs; Authentication retries: 3 (활성화)
```

```
%SSH has not been enabled (비 활성화)
```

Step 2) Cisco IOS 이미지 확인

```
Router# show version
```

```
SSHv2 서버를 지원하는 릴리즈별 k9(3DES) 소프트웨어 이미지를 사용하는지 확인
```

```
(예, 7200p-ipbasek9-mz.152-4.M11.bin)
```

Step 3) SSH 설정

```
Router# config terminal
```

```
Router(config)# hostname <호스트명>
Router(config)# ip domain-name <도메인명>
Router(config)# crypto key generate rsa
```

How many bits in the modulus [512]: 2048

```
Router(config)# ip ssh time-out <초>
Router(config)# ip ssh version 2 (SSH 버전 2 사용)
Router(config)# ip ssh authentication-retries [횟수] <- 재시도 횟수>
```

Step 4) VTY 라인에 SSH 사용 설정

```
Router(config)# line vty 0 4
Router(config-line)# transport input ssh
```

● Radware Alteon

Step 1) /sys/sshd에서 SSH 활성화 확인

Step 2) SSH 설정 방법

```
# cfg
# /sys/sshd ena
# /sys/sshd on
# apply
# save
```

● Juniper Junos

Step 1) SSH 버전 확인

```
user@host# set ssh
```

Step 2) SSH 활성화

```
[edit]
root# set system services ssh
[edit]
root# commit
```

Step 3) Telnet 비활성화

```
[edit]  
root# delete system services telnet  
[edit]  
root# commit
```

● Piolink PLOS

Step 1) SSH 버전 확인

```
(config)# management-access  
(config-management-access)# ssh status enable
```

Step 2) SSH 활성화

```
(config)# management-access  
(config-management-access)# ssh status enable  
(config-management-access)# apply
```

Step 3) Telnet 비활성화

```
(config)# management-access  
(config-management-access)# telnet status disable  
(config-management-access)# apply
```

05. 네트워크 장비

N-09 (중)	네트워크 장비 > 2. 접근 관리
	불필요한 보조 입출력 포트 사용 금지
개요	
점검 내용	사용하지 않는 보조(AUX) 포트 및 콘솔 점검 장비 관리나 운용에 쓰이지 않는 포트 및 인터페이스가 비활성화되어 있는지 점검
점검 목적	사용하지 않는 보조(Auxiliary) 포트의 사용을 제한하여 불필요한 포트 및 인터페이스를 통한 비인가자의 접근을 원천적으로 차단하는지 확인하기 위함
보안 위협	불필요한 포트 및 인터페이스가 활성화되어 있는 경우, 비인가자가 활성화된 포트 및 인터페이스를 통해 네트워크 장비에 접근할 수 있는 위험이 존재함
참고	※ 보조(AUX) 포트 : 모뎀과 연결하여 원격에서 전화를 걸어 접속하거나 다른 네트워크 장비와 null modem 케이블을 연결하여 접속
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : 불필요한 포트 및 인터페이스 사용을 제한한 경우
	취약 : 불필요한 포트 및 인터페이스 사용을 제한하지 않은 경우
조치 방법	불필요한 포트 및 인터페이스 사용 제한 또는 비활성화
조치 시 영향	차단된 포트나 인터페이스를 사용해야 할 경우 별도의 활성화 설정 필요

점검 및 조치 사례

● Cisco IOS

Step 1) 불필요한 포트 및 인터페이스 사용 확인

```
Router# show running
```

불필요한 보조 입출력 포트의 오른쪽 끝부분에 Up (활성화)

불필요한 보조 입출력 포트의 오른쪽 끝부분에 Down (비활성화)

Step 2) AUX 포트 접속 차단

```
Router# config terminal
```

```
Router(config)# line aux 0
```

```
Router(config-line)# no password (어떤 사용자도 접속 금지)
```

```
Router(config-line)# transport input none (어떤 입력도 받지 않음)
```

```
Router(config-line)# no exec (어떤 명령도 실행 안 됨)
```

```
Router(config-line)# exec-timeout 0 1 (1초 지나면 자동 타임아웃)
```

● Juniper Junos

Step 1) 불필요한 포트 및 인터페이스 사용 확인

```
user@host>configure
```

```
[edit]
```

```
user@host#show
```

root authentication 설정을 이용하여 [edit system] 레벨에서 interface 차단 설정 확인

Step 2) 보조(AUX) 포트 비활성화 설정

```
[edit system ports]
```

```
root# set auxiliary disable
```

```
[edit system ports]
```

```
root# commit
```

05. 네트워크 장비

N-10 (중)	네트워크 장비 > 2. 접근 관리
	로그인 시 경고 메시지 설정
개요	
점검 내용	터미널 접속 화면에 비인가자의 불법 접근에 대한 경고 메시지를 표시하도록 설정되어 있는지 점검
점검 목적	경고 메시지 표시 설정 적용 유무를 점검하여 비인가자에게 불법적으로 터미널 접근 시 법적인 처벌에 대해 경각심을 가질 수 있게 하는지 확인하기 위함
보안 위협	터미널 접근 시 경고 메시지가 표시되도록 설정되지 않을 경우, 비인가자가 법 위반에 대한 경각심을 느끼지 않게 되어 더 많은 공격을 시도할 수 있는 원인이 됨
참고	-
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper 등
판단 기준	양호 : 로그인 시 접근에 대한 경고 메시지를 설정한 경우
	취약 : 로그인 시 접근에 대한 경고 메시지를 설정하지 않거나 시스템 관련 정보가 노출되는 경우
조치 방법	네트워크 장비 접속 시 경고 메시지 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) 배너 설정 내용 확인

Router# show running-config

Step 2) 배너 설정

Router# config terminal

Enter configuration commands, one per line. End with CNTL/Z.

Router(config)# banner motd #

Enter TEXT message. End with the character '#'.
<배너 문구 입력> #

Router(config)# banner login #

Enter TEXT message. End with the character '#'.
<배너 문구 입력> #

Router(config)# banner exec #

Enter TEXT message. End with the character '#'.
Router(config)#

<배너 문구 입력> #

Router(config)#

※ 바람직한 배너 예시

This system have to access authorized user and only use for officially.

During using equipment, privacy of individuals is not guaranteed.

All access and usage is monitored and recorded and can be provided evidence as court or related organization.

Use of this system constitutes consent to monitoring for these purposes.

● Radware Alteon

Step 1) banner <string> 설정 내용 확인

Step 2) Banner 설정

cfg

sys

banner <string>

apply

save

● Juniper Junos

Step 1) edit system login 설정 내용 확인

Step 2) [edit system login]

message text

05. 네트워크 장비

N-11 (중)	네트워크 장비 > 2. 접근 관리
	원격로그 서버 사용
개요	
점검 내용	네트워크 장비의 로그를 별도의 원격 로그 서버에 보관하도록 설정하였는지를 점검
점검 목적	네트워크 장비의 로그를 별도의 원격 로그 서버에 보관하도록 설정하여 네트워크 장비에 이상이 발생하거나 로그 저장 공간 부족, 공격자의 로그 삭제나 변조 위험에 대비하기 위함
보안 위협	별도의 로그 서버를 통해 로그를 관리하지 않을 경우, 네트워크 장비에 이상이 발생하거나 공격자의 로그 삭제 및 변조가 일어났을 시 사고 원인 분석에 어려움이 발생함
참고	※ 원격 로그 서버 : 정보시스템(서버, 네트워크, 보안 장비 등)의 로그를 통합적으로 보관하는 서버
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper, Piolink 등
판단 기준	양호 : 별도의 로그 서버를 통해 로그를 관리하는 경우
	취약 : 별도의 로그 서버가 없는 경우
조치 방법	Syslog 등을 이용하여 로그 저장 설정
조치 시 영향	상세한 로깅 설정은 라우터의 성능에 영향을 미칠 수 있음

점검 및 조치 사례

● Cisco IOS

Step 1) Logging 설정 확인

Router# show running-config

Step 2) Log 정보 확인

Router# show logging

Step 3) 라우터 로깅 설정

Router# config terminal

Router(config)# logging on (로그를 console 이외도 전달)

Router(config)# logging trap informational (severity level 설정)

Router(config)# logging 192.168.3.1 (syslog 서버)

Router(config)# logging facility local6 (syslog facility 설정)

Router(config)# logging source-interface serial 0 (syslog interface)

클래스 명	설명
Operator	clear, network, reset, trace, view
read-only	view
Superuser	all
unauthorized	None

● Radware Alteon

Step 1) /syslog/host에서 syslog host 설정 확인

Step 2) switch로 접속

Step 3) # cfg

Step 4) # sys

Step 5) 다음과 같이 설정할 수 있음

/syslog/host: first syslog host의 IP주소 설정

/syslog/host2: second syslog host의 IP주소 설정

Step 6) # apply

Step 7) # save

● Juniper Junos

Step 1) root authentication 설정을 이용하여 [edit system] 레벨에서 syslog 설정 확인

user@host> configure

[edit]

user@host# show version

Step 2) user@host> configure

[edit]

user@host# edit system syslog

[edit system syslog]

user@host# set system syslog file message any error

user@host# set system syslog host 192.168.0.245 any any

user@host# set archive files 5 sizes 5m world-readable

(files 5 – 파일 수를 5개까지 표시, 5m – 최대 사이즈를 5m까지 허용)

- Piolink PLOS

Step 1) configure에서 logging 서버 설정 확인

Step 2) #logging server enable

Step 3) #logging server <ip address> <event> <level>

N-12 (상)	네트워크 장비 > 3. 패치 관리
	주기적 보안 패치 및 벤더 권고사항 적용
개요	
점검 내용	패치 적용 정책에 따라 주기적인 패치를 하고 있는지 점검
점검 목적	네트워크 장비의 보안 수준을 높이고 성능 및 기능 향상하기 위함
보안 위협	알려진 네트워크 장비의 버그나 취약점을 통한 관리자 권한 획득이나 서비스 거부 공격 등을 발생시킬 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	공통
판단 기준	양호 : 주기적으로 보안 패치 및 벤더 권고사항을 적용하는 경우
	취약 : 주기적으로 보안 패치 및 벤더 권고사항을 적용하지 않는 경우
조치 방법	장비별 제공하는 최신 취약점 정보를 파악 후 최신 패치 및 업그레이드를 수행
조치 시 영향	서비스 영향을 고려하여 벤더사와 협의 후 적용

점검 및 조치 사례

● Cisco IOS

Step 1) 버전 정보 확인

```
Router# show version
```

● Juniper Junos

Step 1) 버전 정보 확인

```
user@host# show version
```

● 공통

Step 1) 주기적으로 보안 패치 및 벤더 권고사항을 검토 이후 적용

Step 2) 패치 식별

1. 각 네트워크 장비의 하드웨어, 소프트웨어, EOL, 패치 적용 현황을 문서화하여 관리
2. 운영 중인 네트워크 장비의 보안 패치 및 벤더 권고사항을 입수

05. 네트워크 장비

Step 3) 패치 분석

1. 취약점의 영향도와 발생 가능성을 분석하여 패치 적용 여부와 우선순위를 결정
2. 패치 없이 네트워크 장비 설정 변경 등으로 해결이 가능한 경우 대체 조치를 수행

Step 4) 패치 테스트

1. 테스트베드 또는 시뮬레이션에서 운영환경과 최대한 유사하게 테스트 환경 구축
GNS3(Graphical Network Simulator): 오픈 소스·무료 소프트웨어로 가상과 실제 네트워크를 에뮬레이션, 구성, 테스트, 문제해결을 목적으로 사용
2. 패치가 식별한 문제를 해결하고 정상 동작하는지 체크리스트를 구성하여 검증

Step 5) 패치 적용

1. 패치 적용 전에 네트워크 장비의 이미지와 설정을 백업하여 복구지점을 생성
2. 예비장비를 보유한 경우 운영 장비 설정과 패치를 예비장비에 적용한 후 운영 장비와 교체하고 운영 장비는 비상상황에 대비하여 일정 기간 유지
3. 패치 적용 후 모든 인터페이스와 중요 호스트로의 통신이 정상 동작하는지 확인)

구분	보안패치 및 보안권고 정보제공 사이트
공통	https://www.krcert.or.kr
Cisco	https://software.cisco.com https://tools.cisco.com/security/center
Radware	https://portals.radware.com
Passport	https://support.avaya.com/downloads https://support.avaya.com/security
Juniper	https://support.juniper.net/support/downloads https://advisory.juniper.net
Piollink	파트너사를 통해 지원

N-13 (중)	네트워크 장비 > 4. 로그 관리
	로깅 버퍼 크기 설정
개요	
점검 내용	버퍼 메모리의 크기를 어느 정도로 설정하고 있는지 점검
점검 목적	장비 성능을 고려하여 최대 용량에 가깝도록 버퍼 크기를 설정하도록 함
보안 위협	버퍼 메모리의 용량을 초과하는 로그가 저장될 경우 로그 정보를 잃게 되어 침해사고 발생 시 침입 흔적을 알 수 없는 상황이 발생함
참고	※ 버퍼 메모리: 일반적으로 주기억 장치와 중앙 처리 장치 사이의 명령이나 데이터를 일시 유지하는데 사용되는 고속의 기억 장치. 버퍼 메모리는 주기억 장치보다 메모리 용량은 적지만 고속의 기억 소자를 사용함으로써 주기억 장치와 중앙 처리 사이의 정보의 흐름을 원활하게 함. 버퍼 메모리를 달리 로컬 메모리 혹은 캐시(cache)라고도 함 ※ 기본적으로 로그는 파일이 아닌 버퍼 메모리에 저장됨 ※ 최대 버퍼 크기는 65,500byte이며 버퍼 용량을 높게 설정하면 패킷 전달이 안 되는 경우가 발생함. 일반적으로 16Kbyte에서 32Kbyte의 크기가 적당하며, 최대 용량이 16Kbyte에 못 미치는 장비의 경우 장비 성능을 고려하여 최대 용량에 가깝게 설정하는 것을 권고함
점검 대상 및 판단 기준	
대상	Cisco, Piolink 등
판단 기준	양호 : 저장되는 로그 데이터보다 버퍼 용량이 큰 경우
	취약 : 저장되는 로그 데이터보다 버퍼 용량이 작은 경우
조치 방법	로그에 대한 정보를 확인하여 장비 성능을 고려한 최대 버퍼 크기를 설정
조치 시 영향	버퍼 크기가 장비 성능에 비해 큰 경우 라우터의 성능에 영향을 줌

점검 및 조치 사례

● Cisco IOS

Step 1) 버퍼 메모리 설정 확인

```
Router> enable
```

```
Router# show logging 로그에 대한 정보를 확인
```

메모리(RAM)에 저장된 로그는 'show logging'으로 확인할 수 있고, 'clear logging'을 실행하거나 RAM에 저장된 로그는 전원 종료 시 삭제

Step 2) 버퍼 메모리 설정

```
Router# config terminal
```

```
Router(config)# logging on (로그를 메모리에 백업)
```

```
Router(config)# logging buffered 16000 (16KByte 할당)
```

```
Router(config)# logging buffered information (severity 레벨 설정)
```

● Piolink PLOS

Step 1) (config)# show logging 로그에 대한 정보를 확인

Step 2) (config)#logging buffer <size> (설정 범위 1~1000KB, 기본설정 100KB)

```
(config)#logging priority <event> <level>
```

N-14 (중)	네트워크 장비 > 4. 로그 관리
	정책에 따른 로깅 설정
개요	
점검 내용	정책에 따른 로깅 설정이 이루어지고 있는지 점검
점검 목적	로그 정보를 통해 장비 상태, 서비스 정상 여부 파악 및 보안사고 발생 시 원인 파악 및 각종 침해 사실에 관한 확인을 하기 위함
보안 위협	로깅 설정이 되어있지 않을 경우, 원인 규명이 어려우며, 법적 대응을 위한 충분한 증거로 사용할 수 없음
참고	※ 컴퓨터 관리 > 로컬 사용자 및 그룹 > Remote Desktop Users 그룹에서 추가 가능
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : 로그 기록 정책에 따라 로깅 설정이 되어 있는 경우
	취약 : 로그 기록 정책 미수립 또는 로깅 설정이 미흡한 경우
조치 방법	로그 기록 정책을 수립하고 정책에 따른 로깅 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) 로그에 대한 정보 확인

```
Router> enable
```

```
Router# show logging
```

● Juniper Junos

Step 1) 로그에 대한 정보 확인

```
user@host> configure
```

```
[edit]
```

```
user@host# show log messages
```


- Cisco IOS, Juniper Junos

- Step 1) 콘솔 로깅

콘솔 로그 메시지는 오직 콘솔 포트에서만 보이므로 이 로그를 보기 위해서는 반드시 콘솔 포트에 연결해야 함

- Step 2) Buffered 로깅

Buffered 로깅은 로그를 라우터의 RAM에 저장하는데 이 버퍼가 가득 차게 되면 오래된 로그는 자동으로 새로운 로그에 의해 대체됨

- Step 3) Terminal 로깅

Terminal monitor 명령을 사용하여 로깅을 설정하면 라우터에서 발생하는 로그 메시지를 VTY terminal에 보냄

- Step 4) Syslog

시스코 라우터는 라우터의 로그 메시지가 외부의 syslog 서버에 저장되도록 설정할 수 있음

- Step 5) SNMP traps

SNMP trap이 설정되면 SNMP는 특별한 상황을 외부의 SNMP 서버에 전송하도록 설정할 수 있음

- Step 6) ACL 침입 로깅

표준 또는, 확장된 액세스 리스트를 설정할 때 특정한 룰에 매칭하였을 경우 해당 패킷 정보를 로그에 남기도록 설정할 수 있는데, 이는 액세스 리스트 룰의 끝에 로그나 로그 인풋을 추가하면 됨
로그 인풋은 로그와는 달리 인터페이스 정보도 함께 남기게 되므로 어떤 인터페이스를 통해 로그가 남았는지를 알 수 있음

※ 라우터에 기본적으로 설정된 로그 파일 설정을 변경하지 않으면 로깅을 효율적으로 사용할 수 없으므로 크게 6가지로 이루어진 아래의 방법을 활용해야 함

N-15 (중)	네트워크 장비 > 4. 로그 관리
	NTP 및 시간 동기화 설정
개요	
점검 내용	네트워크 장비의 NTP 서버 연동 및 시간 동기화 설정 적용 여부 점검
점검 목적	시스템 운영 또는 보안 사고 발생으로 인한 로그 분석 과정에서 이벤트 간의 인과 관계 파악에 도움을 주고 로그 자체의 신뢰성을 갖도록 하기 위함
보안 위협	시스템 간 시간 동기화 미흡으로 보안 사고 및 장애 발생 시 로그에 대한 신뢰도 확보가 미흡해짐
참고	※ IOS 12.2 이전 버전을 사용하는 장비에는 접근 통제(ACL) 설정이 되어 있어야 양호
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper 등
판단 기준	양호 : NTP 서버를 통한 시스템 간 실시간 시간 동기화가 설정된 경우
	취약 : NTP 서버와 연동되어 있지 않아 시스템 간 실시간 시간 동기화 설정이 되어있지 않은 경우
조치 방법	NTP 사용 시 신뢰할 수 있는 서버로 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) NTP 서버 설정 확인

```
Router# show running-config
```

Step 2) Global Configuration 모드에서 ntp server 명령을 실행

```
Router# config terminal
```

```
Router(config)# ntp server <NTP 서버 IP>
```

● Radware Alteon

Step 1) /sys/ntp에서 NTP 서버 설정 확인

Step 2) # cfg

```
# /sys/ntp
```

```
# on
```

```
# prsrvr [NTP 서버 IP]
```

```
# intrval [동기화 주기]
```

```
tzone +9:00
```

```
# apply
```

```
# save
```

● Juniper Junos

Step 1) root authentication 설정을 이용하여 [edit system] 레벨에서 NTP 서비스 설정 확인

```
user@host> configure
```

```
[edit]
```

```
user@host# show
```

Step 2) NTP 서버와 네트워크 장비가 부팅될 때 시간 동기화를 위한 NTP 부트 서버를 설정

```
user@host> configure
```

```
[edit]
```

```
user@host# edit system ntp
```

```
[edit system ntp]
```

```
user@host# set server <NTP 서버 IP>
```

```
user@host# set boot-server <NTP 부트 서버 IP>
```

※ 네트워크 장비와 NTP 서버 간 시간 차이가 1000초 이상 다르면 시간 동기화를 하지 않기 때문에 부팅 단계에서 정확한 시간을 확보하도록 부트 서버를 구성

N-16 (하)	네트워크 장비 > 4. 로그 관리
	Timestamp 로그 설정
개요	
점검 내용	네트워크 장비 설정 중 timestamp를 설정하여 로그 시간을 기록할 수 있게 하였는지 점검
점검 목적	네트워크 장비 로그에 시간을 기록하게 설정하여 공격자의 악의적인 행위를 파악하기 위한 로그의 신뢰성을 확보하기 위함
보안 위협	네트워크 장비에 timestamp를 설정하지 않을 경우, 로그에 시간이 기록되지 않아 공격 및 침입시도에 관한 정보를 정확히 분석할 수 없고 로그 기록에 대한 신뢰성을 잃게 됨
참고	※ timestamp : 네트워크 장비 로그 메시지에 관리자가 지정한 형식으로 시간 정보를 남기도록 하는 설정
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : timestamp 로그 설정이 되어 있는 경우
	취약 : timestamp 로그 설정이 되어 있지 않은 경우
조치 방법	로그에 시간 정보가 기록될 수 있도록 timestamp 로그 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) service timestamps 설정 확인

```
Router> enable
```

```
Router# show running-config
```

Step 2) timestamp 로그 설정

1. 로그 메시지의 타임스탬프를 UTC 시간대로 밀리초 단위까지 표시

```
Router# config terminal
```

```
Router(config)# service timestamps log datetime msec show-timezone
```

2. 로그 메시지의 타임스탬프를 로컬 시간대로 밀리초 단위까지 표시

```
Router(config)# clock timezone KST 9
```

```
Router(config)# service timestamps log datetime msec localtime show-timezone
```

05. 네트워크 장비

N-17 (상)	네트워크 장비 > 5. 기능 관리
	SNMP 서비스 확인
개요	
점검 내용	네트워크 장비의 SNMP 서비스를 사용하지 않는 경우 비활성화 상태인지 점검
점검 목적	불필요한 SNMP 서비스 차단하여 SNMP 서비스의 취약점(조작된 MIB 정보를 통한 네트워크 설정 변경, 전송데이터 평문 전송 등)을 이용한 공격을 차단하기 위함
보안 위협	불필요한 SNMP 서비스를 비활성화하지 않은 경우, 비인가자가 SNMP에 무단 접근하여 설정 파일 열람 및 수정이나 정보 수집 및 관리자 권한 획득, DoS 등 다양한 형태의 공격 위험이 존재함
참고	※ SNMP(Simple Network Management Protocol): TCP/IP 기반 네트워크상의 각 호스트에서 정기적으로 여러 정보를 자동으로 수집하여 네트워크 관리를 하기 위한 프로토콜을 의미하며 v1, v2, v3 세 가지 버전이 존재하는데 v2까지도 요청, 응답 패킷이 평문으로 전송되기 때문에 스니핑이 가능하지만, v3 이상부터는 HMAC-MD5 또는 HMAC-SHA 알고리즘 기반의 인증을 제공함 ※ UDP(User Datagram Protocol): 인터넷상에서 서로 정보를 주고받을 때 정보를 보낸다는 신호나 받는다는 신호 절차를 거치지 않고, 보내는 쪽에서 일방적으로 데이터를 전달하는 통신 프로토콜 ※ Community String: SNMP는 MIB라는 정보를 주고받기 위해 인증 과정에서 일종의 비밀번호인 'Community String'을 사용함 ※ DoS(Denial of Service): 시스템을 악의적으로 공격해 해당 시스템의 자원을 부족하게 하여 원래 의도된 용도로 사용하지 못하게 하는 공격을 말하며 특정 서버에게 수많은 접속 시도를 만들어 다른 이용자가 정상적으로 서비스 이용을 하지 못하게 하거나, 서버의 TCP 연결을 바닥내는 등의 공격이 이 범위에 포함됨
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : 사용하지 않는 SNMP 서비스를 비활성화한 경우
	취약 : 사용하지 않는 SNMP 서비스를 비활성화하지 않은 경우
조치 방법	장비별 제공하는 최신 취약점 정보를 파악 후 최신 패치 및 업그레이드를 수행
조치 시 영향	SNMP 서비스를 사용하지 않는 경우 비활성화하고, SNMP 서비스를 사용하는 경우 이전 버전보다 보안 수준이 높은 SNMPv3 사용을 권고

점검 및 조치 사례

● Cisco IOS

Step 1) SNMP 설정 확인

Router# show running-config

Step 2) SNMP 서비스 동작 확인

```
Router# show snmp
```

SNMP 서비스 비활성화 시 “%SNMP agent not enabled” 문구 출력

Step 3) Router# config terminal

```
Router(config)# no snmp-server
```

● Radware Alteon

Step 1) SNMP 서비스 확인

```
>> Main# /cfg/dump
```

```
/c/sys
```

```
snmp r
```

Step 2) >> Main# /cfg/sys/access/snmp

Current SNMP access: disabled

Enter new SNMP access (disabled/read-only/read-write) [d/r/w]:

● Passport

Step 1) SNMP 서비스가 불필요하다면 서비스 중지

● Juniper Junos

Step 1) snmp 서비스 설정 확인

```
user@host# show snmp
```

Step 2) user@host> configure

```
user@host# no set snmp community public
```

● Piolink PLOS

Step 1) SNMP 설정 확인

```
switch# show running-config
```

05. 네트워크 장비

N-18 (상)	네트워크 장비 > 5. 기능 관리
	SNMP Community String 복잡성 설정
개요	
점검 내용	SNMP 서비스 사용 시 Community String을 기본 설정(public, private)으로 사용하고 있는지 점검
점검 목적	SNMP Community String을 공격자가 쉽게 유추하지 못하도록 설정하여 Community String 탈취에 대한 위험을 줄이기 위함
보안 위협	시스템에 기본적으로 설치되는 불필요한 취약 서비스들이 제거되지 않은 경우, 해당 서비스의 취약점으로 인한 공격이 가능하며, 네트워크 서비스의 경우 열린 포트를 통한 외부 침입의 위험이 존재함
참고	※ OS 버전에 따라 '일반적으로 불필요한 서비스' 목록에 나열된 서비스가 제공되지 않을 수 있음
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : SNMP 서비스를 비활성화하거나 SNMP Community String을 복잡성 기준(영어 대·소문자, 숫자, 특수문자 중 3종류 이상을 조합하여 8자리 이상)에 맞게 설정한 경우
	취약 : SNMP Community String을 기본 설정(public, private)으로 사용하고 있거나, 복잡성 기준에 맞지 않게 설정한 경우
조치 방법	public, private 외 복잡성 기준에 맞는 Community String을 설정 ※ SNMP Community String 복잡성 기준 : 영어 대·소문자, 숫자, 특수문자 중 3종류 이상을 조합하여 8자리 이상으로 구성
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) SNMP 설정 확인

Router# show running-config

Step 2) Community String 문자열 변경

Router# config terminal

Router(config)# snmp-server Community <Community String>

● Radware Alteon / Passport

Step 1) SNMP 설정에서 Community String 설정 확인

Step 2) Radware Alteon

```
# cfg/sys/ssnmp  
# rcomm - SNMP read community string 을 설정 (최대 32 자, Default String – public)  
# wcomm - SNMP write community string 을 설정 (최대 32 자, Default String – private)  
# apply  
# save
```

Step 3) Passport

```
# config snmp-v3 community commname <Comm Idx> new-commname <value>
```

● Juniper Junos

Step 1) snmp community 설정에서 Community String 확인

```
[edit]  
user@host# show
```

Step 2) [edit]

```
user@host# set snmp community <Community String> authorization read-only
```

● Piolink PLOS

Step 1) snmp community 설정에서 community string 확인

```
switch# show running-config
```

Step 2) switch# configure

```
switch(config)# snmp  
switch(config-snmp)# community <Community String>  
switch(config-snmp)# status enable  
switch(config-snmp)# apply
```


05. 네트워크 장비

N-19 (상)	네트워크 장비 > 5. 기능 관리
	SNMP ACL 설정
개요	
점검 내용	SNMP 서비스 사용 시 네트워크 장비 ACL(Access List)을 설정하여 SNMP 접속 대상 호스트를 지정하여 접근이 가능한 IP를 제한하였는지 점검
점검 목적	SNMP ACL 설정을 함으로써 임의의 호스트에서 SNMP 접근을 차단하여 네트워크 정보의 노출을 제한하기 위함
보안 위협	비인가자의 SNMP 접근을 차단하지 않을 경우, 공격자가 Community String 추측 공격 후 MIB 정보를 수정하여 라우팅 정보를 변경하거나 터널링 설정을 하여 내부망에 침투할 수 있는 위험이 존재함
참고	-
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : SNMP 서비스를 비활성화하거나 SNMP 접근을 제한하는 ACL을 설정한 경우
	취약 : SNMP 접근을 제한하는 ACL을 설정하지 않은 경우
조치 방법	SNMP 접근에 대한 ACL(Access List) 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) SNMP 설정 확인

Router# show running-config

Step 2) Access-List 설정 확인

Router# show running-config

Step 3) 글로벌 구성 모드에서 snmp-server community 명령어로 ACL 적용

Router# config terminal

Router(config)# access-list <ACL 번호> permit <IP주소>

Router(config)# access-list <ACL 번호> deny any log

Router(config)# snmp-server community <Community String> RO <ACL 번호>

● Passport

Step 1) config snmp-v3 에서 접근목록 설정 확인

Step 2) # config snmp-v3 community create <Comm Idx> <name> <security> [tag]

config snmp-v3 group-member create <user name> <model> [<group name>]

config snmp-v3 group-access create <group name> <prefix> <model> <level>

config snmp-v3 group-access view <group name> <prefix> <model> <level> [read <value>] [write <value>] [notify <value>]

● Juniper Junos

Step 1) edit snmp 에서 접근목록 설정 확인

Step 2) [edit snmp]

user@host# edit client-list <client list name>

[edit snmp client-list <client list name>]

user@host# set default restrict

user@host# set <ip address/range>

user@host# up

[edit snmp]

user@host# edit community <community name>

[edit snmp community <community name>]

user@host#set client-list-name <client list name>

● Piolink PLOS

Step 1) configuration 모드에서 snmp 접근목록 설정 확인

Step 2) 시스템 접근 설정 모드에서 SNMP 서비스에 ACL 설정

configure terminal

(config)# security

(config-security)# system

(config-security-system)# access

(config-security-system-access)# rule <rule-id>

(config-security-system-access-rule[id])# protocol udp

(config-security-system-access-rule[id])# source-ip <IP주소>

05. 네트워크 장비

```
(config-security-system-access-rule[id])# dest-port 161
```

```
(config-security-system-access-rule[id])# interface any
```

```
(config-security-system-access-rule[id])# policy accept
```

```
(config-security-system-access-rule[id])# apply
```

Step 3) 시스템 접근제어 기능의 기본 접근 정책을 차단으로 설정

```
(config-security-access)# default-policy deny
```

※ 기본 접근 정책을 차단으로 변경하기 전에 관리용 포트(mgmt)와 네트워크 장비의 SSH, ICMP 등 다른 서비스와 프로토콜에 필요한 접근허용 규칙을 모두 설정

N-20 (상)	네트워크 장비 > 5. 기능 관리
	SNMP Community 권한 설정
개요	
점검 내용	SNMP Community에 필요하지 않은 쓰기 권한을 허용하는지 점검
점검 목적	불필요한 SNMP Community의 쓰기 권한을 제거함으로써 공격자의 SNMP를 통한 라우터 정보 수정을 막기 위함
보안 위협	SNMP Community 권한이 불필요하게 RW로 설정된 경우, 공격자가 Community String 추측 공격을 통해 Community String을 탈취했을 시 SNMP를 이용하여 네트워크 설정 정보를 변경하여 내부망에 침투할 위험이 존재함
참고	※ SNMP Community String 권한에는 RO(Read Only)와 RW(Read Write) 모드가 있으며 RO 모드의 경우 네트워크 설정값에 대한 열람만 가능하고 RW 모드는 열람 및 수정을 할 수 있음
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport, Juniper, Piolink 등
판단 기준	양호 : SNMP 커뮤니티 권한이 읽기 전용(RO)인 경우
	취약 : SNMP 커뮤니티 권한이 불필요하게 읽기 쓰기(RW)인 경우
조치 방법	SNMP Community String 권한 설정 (RW 권한 삭제 권고)
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) SNMP 설정 확인

```
Router# show running-config
```

Step 2) SNMP Community String 권한 설정(RW 권한 삭제 권고)

```
Router# config terminal
```

```
Router(config)# snmp-server community <String> RO
```

```
Router(config)# snmp-server community <String> RW
```

● Passport

Step 1) config snmp 에서 SNMP community 권한 확인

Step 2) SNMP Community String 권한 설정(RW 권한 삭제 권고)

05. 네트워크 장비

```
# config snmp-v3 community create <Comm Idx> <name> <security> [tag <value>]
# config snmp-v3 group-member create <user name> <model> [<group name>]
# config snmp-v3 group-access create <group name> <prefix> <model> <level>
# config snmp-v3 group-access view <group name> <prefix> <model> <level> [read<value>] [write
<value>] [notify <value>]
```

● Radware Alteon

```
Step 1) >> Main# /cfg/sys/access/snmp
Current SNMP access: read-write
Enter new SNMP access (disabled/read-only/read-write) [d/r/w]: r
>> Main# apply
```

● Juniper Junos

```
Step 1) root authentication 설정을 이용하여 [edit system] 레벨에서 SNMP community 권한 확인
[edit]
user@host# show

Step 2) 읽기 쓰기 권한을 설정한 SNMP Community 삭제
[edit snmp]
user@host# delete community <Community>

Step 3) 읽기 전용 권한으로 SNMP Community 설정
[edit snmp]
user@host# set community <Community> authorization read-only

Step 4) SNMPv3는 SNMP 그룹에 읽기 쓰기 권한 제거
[edit snmp v3 vacm access]
user@host# delete group <그룹> default-context-prefix security-model <보안모델> security-level
<보안 레벨> write-view
```

● Piolink PLOS

```
Step 1) switch# configure
switch(config)# snmp
switch(config-snmp)# policy read-only > apply
```

N-21 (상)	네트워크 장비 > 5. 기능 관리
	TFTP 서비스 차단
개요	
점검 내용	네트워크 장비 서비스 중 불필요한 TFTP 서비스가 구동되어 있거나 TFTP 서비스 사용 시 ACL을 적용하여 허용된 시스템에서만 TFTP 서비스를 사용하도록 설정되어 있는지 점검
점검 목적	인증기능이 없는 TFTP 단점을 보완하기 위해 사용이 허용된 시스템만 TFTP 서비스를 사용하게 하여 TFTP를 이용한 비인가자의 내부 정보 유출을 막고 중요 정보(예: 장비 설정 파일) 등의 정보 유출을 막기 위함
보안 위협	TFTP 서비스는 인증 절차 없이 누구나 사용이 가능한 서비스로 공격자가 TFTP를 통해 악성코드가 삽입된 파일을 올려 사용자에게 배포할 수 있고, 네트워크 설정 파일이나 중요한 내부 정보를 유출할 수 있음
참고	※ TFTP(Trivial File Transfer Protocol) : 임의의 시스템이 원격 시스템으로부터 부팅(Booting)코드를 다운로드하는데 사용하는 프로토콜로 UDP 기반으로 포트는 69번을 사용함. FTP와 같은 기능을 하지만 FTP보다 구현하기 쉽고 사용하기 편하지만, 인증 절차 없이 사용할 수 있어 보안에 취약하고 데이터 전송 과정에서 데이터가 손실될 수 있는 등 불안정한 단점이 있음
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : TFTP 서비스를 차단한 경우
	취약 : 네트워크 장비의 TFTP 서비스를 차단하지 않은 경우
조치 방법	네트워크 장비의 불필요한 TFTP 서비스를 비활성화 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) TFTP 설정 정보 확인

```
Router# show running-config
```

Step 2) Router# config terminal

```
Router(config)# no service tftp
```

05. 네트워크 장비

N-22 (상)	네트워크 장비 > 5. 기능 관리
	Spoofing 방지 필터링 적용
개요	
점검 내용	사설 네트워크, 루프백 등 특수 용도로 배정하여 라우팅이 불가능한 IP주소를 스푸핑 방지 필터링(Anti-Spoofing Filtering)을 적용하여 차단하는지 점검
점검 목적	네트워크 경계에서 소스 IP주소가 명백히 위조된 트래픽을 차단하여 IP 스푸핑 기반 DoS 공격으로부터 인프라를 보호함
보안 위협	IP 스푸핑 기반 DoS 공격 트래픽이 네트워크 장비의 한계용량을 초과하는 경우 정상적인 서비스 불가
참고	※ IP Spoofing: 호스트의 원본 주소가 아닌 다른 소스 주소로 IP 데이터그램을 조작
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : 경계 라우터 또는 보안 장비에 스푸핑 방지 필터링을 적용한 경우
	취약 : 경계 라우터 또는 보안 장비에 스푸핑 방지 필터링을 적용하지 않은 경우
조치 방법	경계 라우터 또는 보안 장비에서 스푸핑 방지 필터링 적용
조치 시 영향	ACL 로그가 과도하게 발생할 경우, 네트워크 장비의 CPU 사용률 증가에 영향을 주므로 로그 설정을 비활성화

점검 및 조치 사례

● Cisco IOS

Step 1) IP spoofing 방지 설정 확인

Router# show running

Step 2) 스푸핑 방지 필터링 ACL 구성

access-list 번호는 100~199구간을 사용하여 Extended access-list를 사용

router# configure terminal

router(config)# access-list <ACL 번호> deny ip 0.0.0.0 0.255.255.255 any

router(config)# access-list <ACL 번호> deny ip 10.0.0.0 0.255.255.255 any

router(config)# access-list <ACL 번호> deny ip 127.0.0.0 0.255.255.255 any

router(config)# access-list <ACL 번호> deny ip 169.254.0.0 0.0.255.255 any

router(config)# access-list <ACL 번호> deny ip 172.16.0.0 0.15.255.255 any

router(config)# access-list <ACL 번호> deny ip 192.0.2.0 0.0.0.255 any

router(config)# access-list <ACL 번호> deny ip 192.168.0.0 0.0.255.255 any

```
router(config)# access-list <ACL 번호> deny ip 224.0.0.0 15.255.255.255 any
router(config)# access-list <ACL 번호> permit ip any any
```

Step 3) 서비스제공업체(SP)와 연결된 인터페이스에 ACL 적용

```
router(config)# interface serial <인터페이스>
router(config-if)# ip access-group <ACL 번호> in
```

● Juniper Junos

Step 1) Configure Firewall Filters와 Apply Firewall Filters 설정 확인

Step 2) 스푸핑 방지 필터링 Firewall Filters 구성

Step 3) IP 대역 지정

```
user@host> configure
[edit]
user@host# edit policy-options
[edit policy-options]
user@host# set prefix-list <prefix-name> 0.0.0.0/8
user@host# set prefix-list <prefix-name> 10.0.0.0/8
user@host# set prefix-list <prefix-name> 127.0.0.0/8
user@host# set prefix-list <prefix-name> 169.254.0.0/16
user@host# set prefix-list <prefix-name> 172.16.0.0/12
user@host# set prefix-list <prefix-name> 192.0.2.0/24
user@host# set prefix-list <prefix-name> 192.168.0.0/16
user@host# set prefix-list <prefix-name> 224.0.0.0/4
```

Step 4) 방화벽 필터 설정

```
[edit]
user@host# edit firewall family inet filter <filter-name>
[edit firewall family inet filter <filter-name>]
user@host# edit term <term-name-1>
[edit firewall family inet filter <filter-name> term <term-name-1>]
user@host# set from source-address <prefix-name>
user@host# set then discard
user@host# up
```



```
[edit firewall family inet filter <filter-name>]
```

```
user@host# set term <term-name-2> then accept
```

Step 5) 서비스제공업체(SP)와 연결된 인터페이스에 방화벽 필터를 적용

```
[edit]
```

```
user@host# set interfaces <인터페이스> unit <유닛> family <패밀리>
```

```
filter input <filter-name>
```

● 공통

Step 1) 특수 용도 주소 차단(RFC 6890 참조)

0.0.0.0/8 자체 네트워크(This host on this network, RFC1122)

10.0.0.0/8 사설 네트워크(Private-Use, RFC1918)

127.0.0.0/8 루프백(Loopback, RFC1122)

169.254.0.0/16 링크 로컬(Link Local, RFC3927)

172.16.0.0/12 사설 네트워크(Private-Use, RFC1918)

192.0.2.0/24 예제 등 문서에서 사용(TEST-NET-1, RFC5737)

192.168.0.0/16 사설 네트워크(Private-Use, RFC1918)

224.0.0.0/4 멀티캐스트(Multicast, RFC5771)

N-23 (상)	네트워크 장비 > 5. 기능 관리
	DDoS 공격 방어 설정 또는 DDoS 장비 사용
개요	
점검 내용	DDoS 공격 방어 설정을 적용하거나 DDoS 대응 장비를 사용하는지 점검
점검 목적	네트워크 장비 또는 DDoS 대응 장비에 DDoS 공격 방어 설정을 적용하여 DDoS 공격 발생 시 피해를 최소화
보안 위협	DDoS 공격으로 인해 사용 가능한 네트워크 및 시스템 리소스 속도가 느려지거나 서버가 손상될 수 있음
참고	※ DDoS(Distributed Denial of Service): 해커에 의해 감염된 다수의 좀비 PC로부터 다량의 트래픽이 특정 서버로 유입되어 시스템, 네트워크에 가용성을 저하시켜 서비스를 방해하는 공격
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : 경계 라우터에서 DDoS 공격 방어 설정을 하거나 DDoS 대응 장비를 사용하는 경우
	취약 : 경계 라우터에서 DDoS 공격 방어 설정을 하지 않거나 DDoS 대응 장비를 사용하지 않는 경우
조치 방법	DDoS 공격 방어 설정 점검
조치 시 영향	필터링 적용 시 사용하는 ACL은 라우터 성능에 많은 영향을 미침

점검 및 조치 사례

● Cisco IOS

Step 1) DDoS 방어 설정 요소 확인

```
Router# show running
```

● Juniper Junos

Step 1) DDoS 방어 설정 요소 확인

```
[edit]
```

```
user@host# show configuration
```

● 공통

Step 1) 스푸핑 방지 필터링 등을 제외한 DDoS 공격 방어 설정은 DDoS 공격 발생 시 공격 유형과 상황을 고려하여 적용

1. ACL(Access Control List)

- 스푸핑 방지 필터링을 사전 적용(N-13)
- DDoS 공격 유형에 따라 공격 대상 IP주소, 프로토콜, 포트를 임시 차단

2. Rate limiting

- 특정 유형의 트래픽에 대역폭과 일정 시간 동안 전송량을 제한
- DDoS 공격 유형에 따라 UDP, ICMP, TCP SYN 패킷의 대역폭을 제한함으로써 다른 서비스에 필요한 대역폭을 확보
- 하드웨어 기반 전용 모듈이 없는 경우 정책 수에 따라 라우터의 CPU 부하가 증가

3. TCP Intercept

- TCP SYN Flooding 공격로부터 서버를 보호하며 Intercept 또는 Watch 모드로 설정
- Intercept 모드는 SYN 패킷을 서버로 전송하지 않고 라우터가 대신 SYN-ACK를 응답하고 정상적으로 TCP 3-way Handshake가 완료되면 서버로 원래 SYN을 전송
- Watch 모드는 SYN 패킷을 서버로 전달하고 30초 안에 연결 성립이 완료되지 않으면 서버에 RST를 전송하여 불완전 연결 상태를 정리
- Intercept 모드는 Watch 모드보다 라우터의 많은 메모리와 CPU를 사용

N-24 (상)	네트워크 장비 > 5. 기능 관리
	사용하지 않는 인터페이스 비활성화
개요	
점검 내용	사용하지 않는 인터페이스가 비활성화 상태인지 점검
점검 목적	필요한 인터페이스만 활성화하여 비인가자가 사용하지 않는 인터페이스를 통하여 네트워크에 접근하는 것을 차단하기 위함
보안 위협	사용하지 않는 포트에 연결된 인터페이스를 Shutdown 하지 않을 경우, 물리적인 내부 접근을 통해 비인가자의 불법적인 네트워크 접근이 가능하게 되며 이로 인하여 네트워크 정보 유출 및 네트워크 손상이 발생할 수 있음
참고	-
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper, Piolink 등
판단 기준	양호 : 사용하지 않는 인터페이스가 비활성화된 경우
	취약 : 사용하지 않는 인터페이스가 비활성화되지 않은 경우
조치 방법	네트워크 장비에서 사용하지 않는 모든 인터페이스 비활성화 설정
조치 시 영향	사용 중인 포트를 비활성화하지 않도록 주의가 필요

점검 및 조치 사례

● Cisco IOS

Step 1) 사용하지 않는 인터페이스 확인

```
Router# show interface
```

비활성화한 인터페이스는 Administratively down으로 표시

Step 2) 사용하지 않는 인터페이스 비활성화(shutdown)

```
Router# config terminal
```

```
Router(config)# interface <인터페이스>
```

```
Router(config-line)# shutdown
```

● Radware Alteon

Step 1) 사용하지 않는 인터페이스 확인

```
>> Main# /cfg/dump
```

```
>> Main# /info/link
```

Step 2) 사용하지 않는 인터페이스 비활성화(dis)

```
>> Main# /cfg/port <포트>/dis
```

```
>> Main# apply
```

● Juniper Junos

Step 1) 사용하지 않는 인터페이스 확인

```
[edit]
```

```
user@host# show interface terse
```

비활성화한 인터페이스는 admin열을 down으로 표시

Step 2) 사용하지 않는 인터페이스 비활성화(disable)

```
[edit]
```

```
user@host# edit interfaces
```

```
[edit interfaces]
```

```
user@host# set <인터페이스> disable
```

● Piolink PLOS

Step 1) 사용하지 않는 인터페이스 확인

```
switch# show running-config
```

```
switch# show port
```

Step 2) 사용하지 않는 인터페이스 비활성화(status disable)

```
switch# configure
```

```
switch(config)# port <포트> status disable
```

```
switch(config)# apply
```

N-25 (중)	네트워크 장비 > 5. 기능 관리
	TCP Keepalive 서비스 설정
개요	
점검 내용	TCP Keepalive 서비스를 사용하는지 점검
점검 목적	네트워크 장비의 Telnet 등 TCP 연결이 원격 호스트 측에 예상치 못한 장애로 비정상 종료된 경우 네트워크 장비가 해당 연결을 지속하지 않고 해제하도록 TCP Keepalive 서비스를 설정
보안 위협	유향 TCP 세션은 무단 접근 및 하이재킹 공격에 취약
참고	※ TCP Keepalive : TCP 연결이 유효한지 확인하기 위해 유향 연결에 주기적으로 응답을 요구하는 패킷을 전송하고 원격 호스트가 일정 시간 동안 응답이 없으면 연결을 끊음
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : TCP Keepalive 서비스를 설정한 경우
	취약 : TCP Keepalive 서비스를 설정하지 않은 경우
조치 방법	네트워크 장비에서 TCP Keepalive 서비스를 사용하도록 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) TCP Keepalive 서비스 설정 확인

```
Router# show running-config
```

Step 2) 네트워크 장비로 들어오는 TCP 연결에 TCP Keepalive 서비스를 설정

```
Router# config terminal
```

```
Router(config) service tcp-keepalives-in
```

Step 3) 네트워크 장비에서 나가는 TCP 연결에 TCP Keepalive 서비스를 설정

```
Router# config terminal
```

```
Router(config) service tcp-keepalives-out
```

05. 네트워크 장비

N-26 (중)	네트워크 장비 > 5. 기능 관리
	Finger 서비스 차단
개요	
점검 내용	네트워크 장비 서비스 중 Finger 서비스를 비활성화하고 있는지 점검
점검 목적	Finger(사용자 정보 확인 서비스)를 통해 네트워크 외부에서 해당 시스템에 등록된 사용자 정보를 확인할 수 있어 비인가자에게 사용자 정보가 조회되는 것을 차단하고자 함
보안 위협	- Finger 서비스로 사용하여 네트워크 장비에 로그인한 계정 ID, 접속 IP 등 중요 정보 노출의 위험이 존재함 - Finger 서비스가 활성화되어 있는 경우, 장비의 접속 상태가 노출될 수 있고 VTY(Virtual Type terminal)의 사용 현황을 원격에서 파악하여 무단 접근을 시도할 위험이 존재함
참고	※ Finger(사용자 정보 확인 서비스) : finger 서비스는 접속된 시스템에 등록된 사용자뿐만 아니라 네트워크를 통하여 연결된 다른 시스템에 등록된 사용자들에 대한 자세한 정보를 보여줌
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : Finger 서비스를 차단하는 경우
	취약 : Finger 서비스를 차단하지 않는 경우
조치 방법	장비별 Finger 서비스 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) Finger 서비스 설정 확인 (12.1(5) 및 12.1(5)T 이상은 기본적으로 비활성화)

```
Router# show running-config
```

Step 2) Finger 서비스 비활성화

```
Router# config terminal
```

```
Router(config)# no service finger (이전)
```

```
Router(config)# no ip finger
```

※ 최근 출시되는 IOS는 no service finger 명령 대신 no ip finger 명령을 사용하기도 함

● Juniper Junos

Step 1) root authentication 설정을 이용하여 [edit system] 레벨에서 Finger 서비스 설정 확인

```
user@host> configure
```

```
[edit]
```

```
user@host# show
```

Step 2) Finger 서비스 비활성화

```
user@host> configure
```

```
[edit]
```

```
user@host# edit system services
```

```
[edit system services]
```

```
user@host# delete finger
```

```
[edit system services]
```

```
user@host# commit
```


05. 네트워크 장비

N-27 (중)	네트워크 장비 > 5. 기능 관리
	웹 서비스 차단
개요	
점검 내용	웹 서비스를 이용하여 네트워크 장비를 관리할 경우, 웹 서비스를 비활성화하거나 허용된 IP에서만 접속할 수 있게 ACL을 적용하였는지 점검
점검 목적	허용된 IP만 웹 관리자 페이지에 접속할 수 있도록 설정하는지 점검하여 비인가자가 웹 관리자 페이지를 공격하여 네트워크 장비를 장악하지 못하도록 하기 위함
보안 위협	허용된 IP에서만 웹 관리자 페이지 접속을 가능하게 ACL 적용하지 않을 경우, 공격자가 알려진 웹 취약점(SQL injection, Command injection 등)이나 자동화된 비밀번호 대입 공격을 통하여 네트워크 장비의 관리자 권한을 획득하여 시스템 무단 변경, 서비스 중단, 데이터 유출 등이 발생할 위험이 존재함
참고	※ IOS 상의 HTTP 서버를 사용해야만 한다면, HTTP WEB_EXEC 서비스를 비활성화함으로써 위험을 감소시킬 수 있음
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : 불필요한 웹 서비스를 차단하거나 허용된 IP에서만 웹서비스 관리 페이지에 접속이 가능한 경우
	취약 : 불필요한 웹 서비스를 차단하지 않은 경우
조치 방법	HTTP 서비스 차단 또는 HTTP 서버를 관리하는 관리자 접속 IP 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) 불필요한 웹서비스 확인

```
Router# show running-config 웹 서비스 설정 확인
```

Step 2) 불필요한 웹서비스 관련 설정

```
Router# config terminal
```

```
Router(config)# no ip http server
```

```
Router(config)# no ip http secure-server
```

```
Router# config terminal
```

```
Router(config)# ip http active-session-modules exclude_webexec
```

```
Router(config)# ip http secure-active-session-modules exclude_webexec
```

● Radware Alteon

Step 1) 불필요한 웹서비스 확인

```
>> Main# /cfg/dump
```

```
>> Main# /info/link
```

Step 2) 불필요한 웹서비스 관련 설정

```
>> Main# /cfg/sys/access/https/https dis
```

```
>> Main# /cfg/sys/access/http dis (HTTP는 Alteon 29.5 버전부터 지원하지 않음)
```

```
>> Main# apply
```

● Juniper Junos

Step 1) 불필요한 웹서비스 확인

```
[edit]
```

```
user@host# show interface terse
```

비활성화한 인터페이스는 admin 열을 down으로 표시

Step 2) 불필요한 웹서비스 관련 설정

```
[edit]
```

```
user@host# delete system services web-management
```

● Piolink PLOS

Step 1) 불필요한 웹서비스 확인

```
switch# show running-config
```

```
switch# show port
```

Step 2) 불필요한 웹서비스 관련 설정

```
switch# configure
```

```
(config)# management-access
```

```
(config-management-access)# http status disable
```

```
(config-management-access)# https status disable
```

05. 네트워크 장비

N-28 (중)	네트워크 장비 > 5. 기능 관리
	TCP/UDP small 서비스 차단
개요	
점검 내용	TCP/UDP Small 서비스가 제한되어 있는지 점검
점검 목적	TCP/UDP Small 서비스를 차단하여 보안성을 높이하고자 함
보안 위협	TCP/UDP Small 서비스를 차단하지 않을 경우, DoS 공격의 대상이 될 수 있음
참고	※ DoS 공격 대상: Cisco 제품의 경우 DoS 공격 대상이 될 수 있는 서비스인 echo, discard, daytime, chargen 을 기본적으로 제공하며 일반적으로 거의 사용하지 않음 ※ TCP/UDP Small 서비스는 IOS 11.3 이상에서는 기본적으로 서비스가 제거된 상태이므로 Small 서버들이 Default로 Disable 되어있지만 낮은 버전의 경우는 직접 설정해 주어야 함
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : TCP/UDP Small 서비스가 제한된 경우
	취약 : TCP/UDP Small 서비스가 제한되지 않은 경우
조치 방법	TCP/UDP Small Service 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) no service tcp-small-servers 및 no service udp-small-servers 설정 확인

```
Router# show running-config
```

Step 2) Global Configuration 모드에서 TCP/UDP Small 서비스를 비활성화 설정

```
Router# config terminal
```

```
Router(config)# no service tcp-small-servers
```

```
Router(config)# no service udp-small-servers
```

```
Router(config)# end
```

N-29 (중)	네트워크 장비 > 5. 기능 관리
	Bootp 서비스 차단
개요	
점검 내용	BOOTP 서비스의 차단 여부 점검
점검 목적	BOOTP 서비스를 차단하여 비인가자에게 OS 정보가 노출되는 것을 방지하기 위함
보안 위협	BOOTP 서비스를 차단하지 않을 경우, 다른 라우터 상의 OS 사본에 접속, OS 소프트웨어 복사본을 다운로드하여 시스템 취약점을 악용하거나 악성 코드 삽입의 위험이 존재함
참고	※ BOOTP 서비스 : 네트워크를 이용하여 사용자가 OS를 로드할 수 있게 하며, 자동으로 IP주소를 받게 하고, 부팅 파일 정보를 서버로부터 요청하여 부팅하는 데 사용하는 프로토콜
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Juniper 등
판단 기준	양호 : BOOTP 서비스가 제한된 경우
	취약 : BOOTP 서비스가 제한되지 않은 경우
조치 방법	장비별 BOOTP 서비스 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) ip bootp server 설정 확인

```
Router# show running-config
```

Step 2) BOOTP 차단 설정

```
Router# config terminal
```

```
Router(config)# no ip bootp server
```

또는

DHCP 서비스(DHCP 서버 및 릴레이)는 유지하고 BOOTP만 차단하는 경우

```
Router(config)# ip dhcp bootp ignore
```

※ 라우터를 자동 재부팅하는 취약점이 존재하므로 서비스를 차단하여 방어하기를 권고함

- Radware Alteon

Step 1) #bootp disable 설정 확인

Step 2) BOOTP 차단 설정(dis)

```
>> Main# /cfg/sys/bootp dis
```

```
>> Main# apply
```

- Juniper Junos

Step 1) bootp 서비스 설정 확인

```
user@switch>show configuration & show interfaces detail
```

Step 2) DHCP 서버 IP주소와 서버가 연결된 스위치에 대한 인터페이스 지정 옵션 제거

```
user@switch> configure
```

```
[edit]
```

```
user@switchr# edit forwarding-options helpers bootp
```

```
[edit forwarding-options helpers bootp]
```

```
user@switch# no set interface <인터페이스 포트> server <주소>
```

N-30 (중)	네트워크 장비 > 5. 기능 관리
	CDP 서비스 차단
개요	
점검 내용	CDP 서비스를 차단하는지 점검
점검 목적	동일 네트워크에 있는 다른 Cisco 장비들의 정보 유출 방지 및 DoS 공격을 차단하기 위함
보안 위협	보안이 검증되지 않은 서비스로 비인가자가 다른 Cisco 장비의 정보를 획득할 수 있으며, Routing Protocol Attack을 통해 네트워크 장비의 DoS(서비스거부 공격)의 위험이 존재함
참고	※ CDP(Cisco Discovery Protocol): Cisco 제품의 관리를 목적으로 만든 프로토콜로 같은 네트워크에 있는 장비들과 정보를 공유하고, 같은 세그먼트에 있는 다른 라우터에 IOS version, Model, device 등의 정보를 제공함
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : CDP 서비스를 차단하는 경우
	취약 : CDP 서비스를 차단하지 않는 경우
조치 방법	- 장비별 CDP 서비스 제한 설정 - CDP는 Cisco 전용 프로토콜이지만 일부 다른 벤더도 지원하며, CDP와 유사한 IEEE 표준인 LLDP(Link Layer Discovery Protocol, IEEE 802.1AB)도 불필요할 경우 비활성화
조치 시 영향	인터넷 전화(VoIP) 구성방식에 따라 IP 전화기와 스위치가 CDP 또는 LLCP를 사용

점검 및 조치 사례

● Cisco IOS

Step 1) cdp run, global cdp 설정 확인

```
Router# show running-config
```

```
Router# show cdp
```

Step 2) cdp 서비스 차단 설정

```
Router# config terminal
```

```
Router(config)# no cdp run
```

```
Router(config)# interface FastEthernet0/1
```

```
Router(config-if)# no cdp enable
```

※ CDP를 라우터 전체에서 사용하지 못하도록 하기 위해서는 no cdp run 명령어가 사용되며, 특정 인터페이스에서 사용하지 못하도록 하려면 no cdp enable 명령어를 사용함

05. 네트워크 장비

N-31 (중)	네트워크 장비 > 5. 기능 관리
	Directed-broadcast 차단
개요	
점검 내용	Directed-broadcast를 차단하는지 점검
점검 목적	Directed-broadcast 서비스 차단을 통해 DoS 공격을 방지하기 위함
보안 위협	IP Directed-Broadcast는 Unicast IP 패킷이 특정 서브넷에 도착했을 때 Link-Layer Broadcast로 전환되는 것을 허용함. 이것은 보통 악의적으로 이용되며, 특히 SMURF 공격에 이용됨
참고	※ SMURF 공격 : IP Broadcast나 기타 인터넷 운용 측면을 이용하여 인터넷망을 공격하는 행위로 Broadcast에 대한 응답받을 IP주소를 변조하여 해당 IP주소 호스트에 DoS 공격을 감행하는 공격 기법
점검 대상 및 판단 기준	
대상	Cisco, Alteon, Passport 등
판단 기준	양호 : Directed Broadcasts를 차단하는 경우
	취약 : Directed Broadcasts를 차단하지 않는 경우
조치 방법	장치별로 Directed Broadcasts 제한 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) Directed-Broadcast 설정 확인

Router# show running-config

Step 2) Interface Configuration 모드에서 no ip directed-broadcast 명령을 실행하여 비활성화

Router# config terminal

Router(config)# interface <인터페이스>

Router(config-if)# no ip directed-broadcast

● Radware Alteon

Step 1) dirbr에서 disable 설정 확인

Step 2) dirbr 서비스 비활성화

cfg/13/frwd

```
# dirbr disable
```

```
# apply
```

```
# save
```

● Passport

Step 1) config에서 ip directed-broadcast 설정 확인

Step 2) directed-broadcast 서비스 비활성화

```
# config vlan <vid> ip directed-broadcast
```

```
# disable
```


05. 네트워크 장비

N-32 (중)	네트워크 장비 > 5. 기능 관리
	Source Routing 차단
개요	
점검 내용	Source Routing을 차단하는지 점검
점검 목적	인터페이스마다 no ip source-route를 적용하여 ip spoofing을 차단함
보안 위협	공격자가 Source Routing 된 패킷을 네트워크 내부에 발송할 수 있는 경우, 수신된 패킷에 반응하는 메시지를 가로채어 사용자 호스트를 마치 신뢰 관계에 있는 호스트와 통신하는 것처럼 만들 수 있음
참고	※ Source Routing : 송신 측에서 routing 경로 정보를 송신 데이터에 포함해 Routing 시키는 방법으로 패킷이 전송되는 경로를 각각의 시스템이나 네트워크에 설정된 라우팅 경로를 통하지 않고 패킷 발송자가 설정할 수 있는 기능임
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : ip-source-route를 차단하는 경우
	취약 : ip-source-route를 차단하지 않는 경우
조치 방법	각 인터페이스에서 ip-source-route 차단 설정
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) Global Configuration 모드에서 no ip source-route 명령어를 실행하여 비활성화

```
Router# config terminal
```

```
Router(config)# no ip source-route
```

● Juniper Junos

Step 1) ip source route 설정 확인

```
user@host# show route
```

Step 2) [edit]

```
user@host# set chassis no-source-route
```

※ Junos 8.5 버전 이후부터 기본적으로 IPv4 소스 라우팅 비활성화 상태

N-33 (중)	네트워크 장비 > 5. 기능 관리
	Proxy ARP 차단
개요	
점검 내용	Proxy ARP를 차단하는지 점검
점검 목적	Proxy ARP 차단으로 IP와 MAC이 관련된 호스트에 대해 정상적인 통신을 유지함
보안 위협	Proxy ARP를 차단하지 않을 경우, 악의적인 사용자가 보낸 거짓 IP와 MAC 정보를 보관하게 되며 이로 인해 호스트와 호스트 사이에서 정상적인 통신이 이루어지지 않을 수 있음
참고	※ Proxy ARP : 동일 서브넷에서 다른 호스트를 대신하여 ARP Request에 응답하는 기술
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : Proxy ARP를 차단하는 경우
	취약 : Proxy ARP를 차단하지 않는 경우
조치 방법	각 인터페이스에서 Proxy ARP 비활성화 설정
조치 시 영향	게이트웨이 또는 서브넷마스크를 잘못 설정한 호스트가 네트워크 장비의 Proxy ARP에 의해 통신한 상태인 경우, 가능한 경우를 고려하여 사전조사 등 필요

점검 및 조치 사례

● Cisco IOS

Step 1) Interface Configuration 모드에서 no ip proxy-arp 명령어를 실행하여 비활성화

```
Router# config terminal
```

```
Router(config)# interface <인터페이스>
```

```
Router(config-if)# no ip proxy-arp
```

● Juniper Junos

Step 1) 각 인터페이스에서 proxy-arp 설정을 확인

```
user@host# show
```

Step 2) [edit interfaces <인터페이스> unit <유닛>]

```
user@host# delete proxy-arp
```

05. 네트워크 장비

N-34 (중)	네트워크 장비 > 5. 기능 관리
	ICMP unreachable, redirect 차단
개요	
점검 내용	ICMP unreachable, ICMP redirect를 차단하는지 점검
점검 목적	- ICMP unreachable 차단으로 DoS 공격을 차단하고 공격자가 네트워크 스캔 시 소요되는 시간을 길어지게 하여 스캔 공격을 지연 및 차단함 - ICMP redirect 차단으로 라우팅 테이블이 변경되는 것을 차단하기 위함
보안 위협	- ICMP unreachable을 차단하지 않을 경우, 공격자의 스캔 공격을 통해 시스템의 현재 운영되고 있는 상태 정보가 노출될 수 있음 - ICMP redirect을 차단하지 않을 경우, 호스트 패킷 경로를 다시 지정하는 과정에서 특정 목적지로 가기 위해 고의로 패킷 경로를 변경하여 가로챌 수 있음 - 연속적으로 ICMP의 port-unreachable frame을 보내서 시스템의 성능을 저하 또는 마비시킬 수 있음
참고	※ ICMP unreachable: ICMP unreachable 메시지에는 특정 호스트 및 게이트웨이에 패킷을 보냈을 때 어떠한 이유로 전달될 수 없는지 나타내는 코드들을 포함하고 있음 ※ ICMP redirect: ICMP redirect는 라우터가 송신 측 호스트에 적합하지 않은 경로로 설정되어 있으면 해당 호스트에 대한 최적 경로를 다시 지정해주는 용도로 사용됨
점검 대상 및 판단 기준	
대상	Cisco, Juniper 등
판단 기준	양호 : ICMP unreachable, ICMP redirect를 차단하는 경우
	취약 : ICMP unreachable, ICMP redirect를 차단하지 않는 경우
조치 방법	각 인터페이스에서 ICMP unreachables, ICMP redirects 비활성화
조치 시 영향	특정 경로를 찾아갈 때 많은 시간이 경과 될 수 있음

점검 및 조치 사례

● Cisco IOS

Step 1) 각 인터페이스에서 no ip unreachables과 no ip redirects 설정을 확인

```
Router> enable
```

```
Router# show running-config
```

※ Global Configuration 모드의 ip icmp redirects 명령어는 ICMP redirection 메시지 유형을 호스트 또는 서브넷으로 지정하는 명령어로 ICMP redirection 차단과 무관

Step 2) Interface Configuration 모드에서 no ip unreachable와 no ip redirects 명령어를 실행

```
Router# config terminal
Router(config)# interface <인터페이스>
Router(config-if)# no ip unreachable
Router(config-if)# no ip redirects
Router(config-if)# end
```

※ Null Interface는 no ip unreachable 외 다른 모든 명령어는 무시됨

● Juniper Junos

Step 1) ICMP unreachable, ICMP redirects 적용 확인

```
user@host# show
```

Step 2) ICMP redirect 차단

전체 장비에서 ICMP redirect 비활성화

```
[edit system]
```

```
user@host#set no-redirects
```

또는 특정 인터페이스에서 ICMP Redirect 비활성화

```
[edit interfaces]
```

```
user@host#set <인터페이스> unit <유닛> family <패밀리> no-redirects
```

05. 네트워크 장비

N-35 (중)	네트워크 장비 > 5. 기능 관리
	identd 서비스 차단
개요	
점검 내용	identd 서비스를 차단하는지 점검
점검 목적	불필요한 identd 서비스를 차단하여 잠재적인 취약점 및 공격에 노출 방지
보안 위협	identd 서비스는 TCP 세션의 사용자 식별이 가능하여 비인가자에게 사용자 정보가 노출될 수 있음
참고	※ identd 서비스 : 특정 TCP 연결을 시작한 사용자의 신원을 확인하는 서비스(113/TCP) ※ 사용자가 서버로 TCP 연결을 시작한 경우 서버는 클라이언트의 identd 서비스에 TCP 세션의 포트 번호를 보내 클라이언트 운영체제와 사용자 ID를 조회 가능 ※ 클라이언트의 정보에 의존하기 때문에 인증 또는 접근제어 용도로 사용할 수 없음 ※ IOS 12.2 이상 Default로 차단되어 있음
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : identd 서비스를 차단하는 경우
	취약 : identd 서비스를 차단하지 않는 경우
조치 방법	identd 서비스 비활성화
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

Cisco IOS

Step 1) identd 서비스 확인

Router> enable

Router# show running-config

Step 2) Global Configuration 모드에서 no ip identd 명령어를 실행하여 비활성화

Router# config terminal

Router(config)# no ip identd

※ 기본적으로 ip identd 설정을 별도로 설정하지 않으면 비활성화 상태이며, 구성에서 no ip identd 명령어가 표시되지 않음

N-36 (중)	네트워크 장비 > 5. 기능 관리
	Domain Lookup 차단
개요	
점검 내용	Domain Lookup을 차단하는지 점검
점검 목적	명령어를 잘못 입력할 때 발생하는 불필요한 Domain Lookup을 차단
보안 위협	불필요한 DNS broadcast traffic과 사용자 대기시간 발생
참고	※ Domain Lookup : Cisco 장비는 Privileged Exec 모드에서 명령어가 아닌 문자열을 입력하면 호스트 이름으로 간주하고 Domain Lookup을 시도하며, DNS를 설정하지 않은 경우, DNS Broadcast Query를 수행하는 1분여간 사용자 입력을 받지 않음
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : Domain Lookup을 차단하는 경우
	취약 : Domain Lookup을 차단하지 않은 경우
조치 방법	Domain Lookup 비활성화
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) no ip domain-lookup 설정을 확인

```
Router> enable
```

```
Router# show running-config
```

Step 2) Global Configuration 모드에서 no ip domain lookup 명령어를 실행

```
Router# config terminal
```

```
Router(config)# no ip domain lookup
```

또는

```
Router(config)# no ip domain-lookup
```

※ IOS 12.2 버전부터 ip domain-lookup을 ip domain lookup로 변경하고 두 명령어 모두 지원

05. 네트워크 장비

N-37 (중)	네트워크 장비 › 5. 기능 관리	
	pad 차단	
개요		
점검 내용	PAD 서비스를 차단하는지 점검	
점검 목적	X.25 프로토콜을 사용하지 않는 경우 PAD 서비스를 중지	
보안 위협	PAD와 같이 불필요한 서비스를 차단하지 않을 경우, 잠재적인 취약점 및 공격에 노출될 수 있음	
참고	※ PAD(Packet Assembler/Disassembler) : X.25 패킷 교환망에 패킷 처리 기능이 없는 비 동기형 단말기의 연결을 제공하는 서비스, 비 동기형 단말기로부터 수신한 문자 스트림을 X.25 패킷으로 분해하고 반대로 X.25 패킷을 문자 스트림으로 재조합하여 상호 전송 ※ X.25 : 패킷교환 데이터 전송 서비스를 위한 ITU-T 표준 프로토콜(1976년 개발), 패킷 교환설비와 패킷형 단말기의 통신절차는 X.25, 패킷 교환설비와 비동기형 단말기의 통신절차는 X.3, X.28, X.29를 사용	
점검 대상 및 판단 기준		
대상	Cisco 등	
판단 기준	양호 : PAD 서비스를 차단하는 경우	
	취약 : PAD 서비스를 차단하지 않은 경우	
조치 방법	PAD 서비스 비활성화	
조치 시 영향	일반적인 경우 영향 없음	

점검 및 조치 사례

● Cisco IOS

Step 1) no service pad 설정을 확인

```
Router> enable
```

```
Router# show running-config
```

Step 2) Global Configuration 모드에서 no service pad 명령어를 사용하여 비활성화

```
Router# config terminal
```

```
Router(config)# no service pad
```

N-38 (중)	네트워크 장비 > 5. 기능 관리
	mask-reply 차단
개요	
점검 내용	mask-reply를 차단하는지 점검
점검 목적	내부 네트워크의 서브넷마스크 정보를 요청하는 ICMP 메시지에 네트워크 장비가 응답하지 않도록 mask-reply를 차단 설정
보안 위협	mask-reply를 차단하지 않는 경우 비인가자에게 내부 서버 네트워크의 서브넷마스크 정보가 노출될 수 있음
참고	※ mask-reply : 네트워크 장비는 ICMP Address Mask Request 메시지에 대한 응답으로 인터페이스의 서브넷마스크 정보를 제공
점검 대상 및 판단 기준	
대상	Cisco 등
판단 기준	양호 : mask-reply를 차단하는 경우
	취약 : mask-reply를 차단하지 않은 경우
조치 방법	각 인터페이스에서 mask-reply 비활성화
조치 시 영향	일반적인 경우 영향 없음

점검 및 조치 사례

● Cisco IOS

Step 1) mask-reply 차단 여부 확인

```
Router# show running-config
```

Step 2) show ip interface 실행 결과에서 ICMP Address mask-reply 차단 여부 확인

```
Router# show ip interface
```

```
Serial1/0 is up, line protocol is up (connected)
```

```
ICMP mask replies are never sent
```

Step 3) Interface Configuration 모드에서 no ip mask-reply 명령어를 사용하여 비활성화

```
Router# config terminal
```

```
Router(config)# interface <인터페이스>
```

```
Router(config-if)# no ip mask-reply
```

※ 기본적으로 ip mask-reply 명령은 비활성화 상태이기 때문에 구성 내용에서 no ip mask-reply 명령이 표시되지 않음